



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services



دبلوم امن المعلومات

الفصل 5: تقييم المخاطر القانونية والأخلاقية



دبلوم امن المعلومات

اسم المقرر:	السياسات والتشريعات والاخلاقيات والالتزام بها
رمز المقرر:	ISE123
الموضوع:	الفصل 5: تقييم المخاطر القانونية والأخلاقية



يحلل خرق سياسة أمنية من حيث الأصل المتأثر والأثر والمسؤوليات.



يميز المخاطر القانونية عن المخاطر الأخلاقية والتشغيلية في المؤسسة الرقمية.

يقارن بين التدريب والتوعية والمراجعة الداخلية بوصفها أدوات للحد من المخاطر.



يطبق مصفوفة تقييم مخاطر نوعية لترتيب أولويات المعالجة.



يقترح تقريراً أولياً موثقاً يتضمن إجراءً تصحيحياً ومسار متابعة.





خريطة الفصل

ينظم الفصل في ست وحدات تعلم مترابطة.





- ◀ يتكون الفصل من ست وحدات غير متزامنة مستقلة، مدة كل وحدة 70 دقيقة.
- ◀ يبدأ المتعلم كل وحدة بتمهيد وأهداف، ثم يدرس محاورها وينفذ النشاط المحدد ويجري تحقيقاً ذاتياً قصيراً قبل قراءة الملخص.
- ◀ يوزع اختبار الفصل القصير على نقاط تحقق وحدوية داخل المنصة، بينما ينفذ الواجب والمشروع التراكمي وفق الزمن المعلن لهما.
- ◀ مجموع وقت الفصل 420 دقيقة وفق الخطة المعتمدة.



خطة الوحدة الزمنية (تابع)



الوحدة	المحور الرئيس	دراسة المحتوى	النشاط والتطبيق	التحقق الذاتي	الزمن
1	فئات المخاطر والأصول	40 دقيقة	25 دقيقة	5 دقائق	70 دقيقة
2	خرق السياسة والخصوصية	40 دقيقة	25 دقيقة	5 دقائق	70 دقيقة
3	التقييم النوعي للمخاطر	40 دقيقة	25 دقيقة	5 دقائق	70 دقيقة
4	بدائل معالجة المخاطر	40 دقيقة	25 دقيقة	5 دقائق	70 دقيقة
5	التوثيق والإجراءات التصحيحية	45 دقيقة	20 دقيقة	5 دقائق	70 دقيقة
6	أدوات الحد من المخاطر والمتابعة والمشروع	40 دقيقة	20 دقيقة. تشمل مرحلة المشروع	10 دقائق	70 دقيقة



شرط إكمال الوحدة: دراسة الشرائح والمستندات المحددة، تنفيذ النشاط، ثم الحصول على 60% على الأقل في نقطة التحقق الوحدوية.



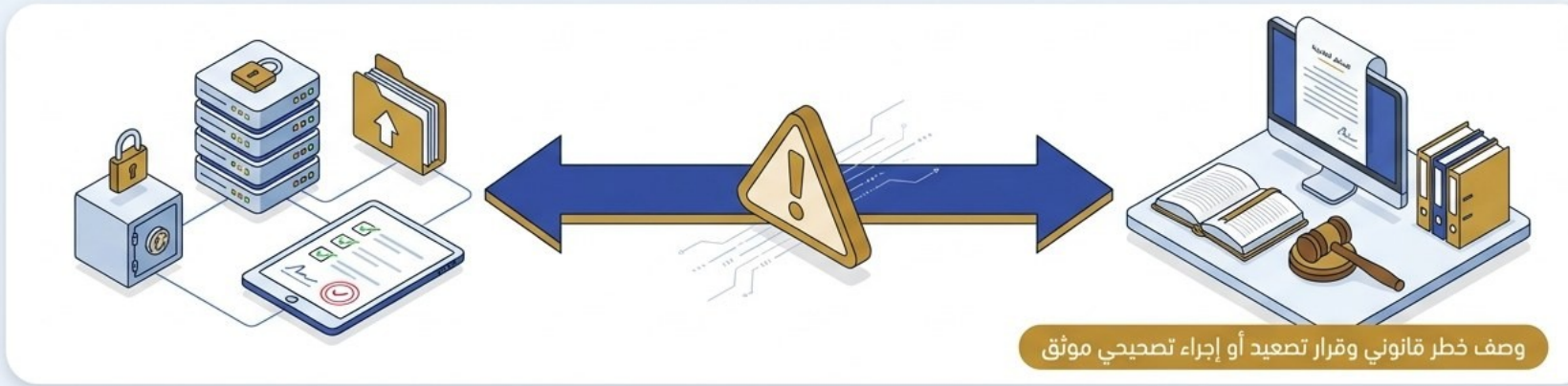
- ◀ المخاطر القانونية هي احتمال ارتباط واقعة ما بمخالفة نظام أو التزام تنظيمي أو حق متعلق بالبيانات والمعلومات.
- ◀ وظيفتها توجيه المؤسسة إلى التعرف المبكر على الوقائع التي تحتاج إلى توثيق وتصعيد ومراجعة مختصة.
- ◀ **الوظيفة:** دعم قرار التصعيد المنظم.
- ◀ **المسؤوليات:** تحديد الواقعة بدقة، حفظ الوقائع الموثقة، التصعيد الداخلي، إحالة المسألة للمختص النظامي، متابعة القرار المعتمد.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، نظام مكافحة جرائم المعلوماتية، وسياسات وإجراءات المؤسسة. أما نظام إدارة أمن المعلومات فهو إطار إداري داعم لإدارة الخطر وليس تشريعاً ملزماً بذاته.
- ◀ **الأجهزة:** سجل المخاطر، سجل حادث أو مخالفة، سجل قرارات، مستودع وثائق معتمد.
- ◀ **وحدة البيانات:** وصف خطر قانوني وقرار تصعيد أو إجراء تصحيحي موثق.
- ◀ **مثال:** إرسال ملف رواتب الموظفين إلى المورد (منشأة سعودية) في الواقعة IR-2026-05-017 يمثل خطراً قانونياً محتملاً يحتاج إلى توثيق وتصعيد.



المخاطر القانونية (Legal Risk) (الشكل)

SLIDE 5 • LEGAL RISK

المخاطر القانونية



الأجهزة والأدوات

- سجل المخاطر
- سجل حادث أو مخالفة
- سجل قرارات
- مستودع وثائق معتمد

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- نظام مكافحة جرائم المعلوماتية
- سياسات وإجراءات المؤسسة.
- أما نظام إدارة أمن المعلومات فهو إطار إداري داعم لإدارة الخطر وليس تشريعاً ملزماً بذاته.

الوظائف الرئيسية

- دعم قرار التصعيد المنظم
- تحديد الواقعة بدقة
- حفظ الوقائع الموثقة
- التصعيد الداخلي
- إحالة المسألة للمختص النظامي

إرسال ملف رواتب الموظفين إلى المورد (منشأة سعودية) في الواقعة IR-2026-05-017 يمثل خطراً قانونياً محتملاً يحتاج إلى توثيق وتصعيد.

المخاطر القانونية هي احتمال ارتباط واقعة ما بمخالفة نظام أو التزام تنظيمي أو حق متعلق بالبيانات والمعلومات.



- ◀ المخاطر الأخلاقية هي احتمال أن يؤدي سلوك أو قرار مهني إلى ضرر بالسرية أو الثقة أو العدالة أو مصالح أصحاب البيانات.
- ◀ وظيفتها إضافة معيار الحكم المهني إلى الحد الأدنى من الالتزام النظامي.
- ◀ **الوظيفة:** تقويم أثر القرار على الثقة والعدالة.
- ◀ **المسؤوليات:** تقدير أثر القرار على الأفراد، مقارنة البدائل المتاحة، توثيق المبرر المهني، الإبلاغ عن السلوك غير الملائم.
- ◀ **البروتوكولات والمعايير:** مدونة الأخلاقيات، سياسة الخصوصية، سياسة الاستخدام المقبول، الضوابط الأساسية للأمن السيبراني.
- ◀ **الأجهزة:** سجل قرار أخلاقي، نموذج إفصاح، سجل تعارض مصالح.
- ◀ **وحدة البيانات:** قرار مهني مبرر وخطة معالجة سلوكية أو تنظيمية.
- ◀ **مثال:** الاطلاع على ملف رواتب الموظفين بدافع الفضول يضر بسرية البيانات والثقة المهنية، ولو لم يثبت في البداية أثر تشغيلي ظاهر.



المخاطر الأخلاقية (Ethical Risk) (الشكل)

SLIDE 6 · ETHICAL RISK

المخاطر الأخلاقية



الاطلاع على ملف رواتب الموظفين بدافع الفضول يضر بسرية البيانات والثقة المهنية، ولو لم يثبت في البداية أثر تشغيلي ظاهر.

الأجهزة والأدوات

- سجل قرار أخلاقي
- نموذج إفصاح
- سجل تعارض مصالح

البروتوكولات والمعايير

- مدونة الأخلاقيات
- سياسة الخصوصية
- سياسة الاستخدام المقبول
- الضوابط الأساسية للأمن السيبراني

الوظائف الرئيسية

- تقويم أثر القرار على الثقة والعدالة
- تقدير أثر القرار على الأفراد
- مقارنة البدائل المتاحة
- توثيق المبرر المهني
- الإبلاغ عن السلوك غير اللائق

المخاطر الأخلاقية هي احتمال أن يؤدي سلوك أو قرار مهني إلى ضرر بالسرية أو الثقة أو العدالة أو مصالح أصحاب البيانات.



المخاطر التشغيلية (Operational Risk)



- ◀ المخاطر التشغيلية هي مخاطر قد تؤثر في استمرارية العمل أو كفاءة الخدمة أو قدرة المؤسسة على حماية أصولها.
- ◀ وظيفتها ربط قرار المخاطر بسياق الخدمة والعمليات والأصول المتأثرة.
- ◀ **الوظيفة:** ربط الخطر باستمرارية الخدمة.
- ◀ **المسؤوليات:** تحديد أثر العمل، تعيين مالك مسؤول، تقدير الأولوية، اختيار المعالجة، متابعة التنفيذ.
- ◀ **البروتوكولات والمعايير:** عملية إدارة المخاطر، نظام إدارة أمن المعلومات.
- ◀ **الأجهزة:** سجل الأصول، سجل المخاطر، خطة معالجة.
- ◀ **وحدة البيانات:** مستوى خطر نوعي وخطة معالجة.
- ◀ **مثال:** استمرار صلاحيات موظف منقول للوصول إلى عروض أسعار الموردين لمدة شهرين يهدد سرية الوثائق وكفاءة إدارة الوصول، ولذلك يسجل في السجل R-2026-06 كمخاطرة حرجية.



المخاطر التشغيلية (Operational Risk) (الشكل)

SLIDE 7 · OPERATIONAL RISK

المخاطر التشغيلية



الأجهزة والأدوات

- سجل الأصول
- سجل المخاطر
- خطة معالجة

البروتوكولات والمعايير

- عملية إدارة المخاطر
- نظام إدارة أمن المعلومات

الوظائف الرئيسية

- ربط الخطر باستمرارية الخدمة
- تحديد أثر العمل
- تعيين مالك مسؤول
- تقدير الأولوية
- اختيار المعالجة

استمرار صلاحيات موظف منقول للوصول إلى عروض أسعار الموردين لمدة شهرين يهدد سرية الوثائق وكفاءة إدارة الوصول، ولذلك يسجل في السجل R-2026-06 كمخاطرة درجة.

المخاطر التشغيلية هي مخاطر قد تؤثر في استمرارية العمل أو كفاءة الخدمة أو قدرة المؤسسة على حماية أصولها.

الفرق بين المخاطر القانونية والأخلاقية والتشغيلية

- ◀ تختلف فئات المخاطر في مصدر الأثر ومالك المعالجة، لكنها قد تجتمع في الواقعة نفسها.
- ◀ الخطر القانوني يرتبط بالالتزامات والحقوق النظامية.
- ◀ والخطر الأخلاقي يرتبط بالثقة والسرية والعدالة.
- ◀ أما الخطر التشغيلي فيرتبط بالخدمة والأصول والعمليات.
- ◀ لذلك ينبغي تحليل الواقعة من أكثر من زاوية قبل اختيار المعالجة.

فئة الخطر	السؤال الرئيس	أثر محتمل	مثال من السجل
قانوني	هل توجد التزامات أو حقوق متأثرة؟	مساءلة أو تصعيد منظم	إرسال بيانات شخصية
أخلاقي	هل تضررت السرية أو الثقة أو العدالة؟	فقدان الثقة المهنية	مشاركة حساب مشرف
تشغيلي	هل تأثرت الخدمة أو الضوابط؟	ضعف في استمرارية العمل	صلاحيات لم تسحب



نشاط تحقق سريع، تصنيف فئة الخطر



- ◀ اقرأ الموقف الآتي: احتفظ فريق عمل بملف بيانات مستفيدين في مساحة مشاركة عامة من دون مالك أصل محدد أو صلاحيات وصول واضحة.
- ◀ صنف المخاطر المحتملة إلى قانونية وأخلاقية وتشغيلية.
- ◀ اكتب سبباً مختصراً لكل تصنيف، ثم حدد أي فئة تستدعي أولوية المعالجة في رأيك.
- ◀ الزمن المتوقع خمس دقائق.



- ◀ ينشأ خطر قانوني لأن الملف قد يحتوي بيانات شخصية يمكن الوصول إليها خارج الصلاحيات المنظمة.
- ◀ وينشأ خطر أخلاقي لأن غياب المالك والصلاحيات يضعف سرية البيانات والمساءلة عنها.
- ◀ وينشأ خطر تشغيلي لأن المؤسسة لا تستطيع تحديد المسؤول عن المراجعة أو تحديث الوصول.
- ◀ تبدأ المعالجة بتعيين مالك أصل ونقل الملف إلى مساحة مقيدة الوصول.

(Information Asset) الأصل المعلوماتي

- ◀ الأصل المعلوماتي هو المعلومات أو السجلات أو الأنظمة أو الخدمات المرتبطة بالمعلومات التي تكون ذات قيمة للجهة.
- ◀ وهو تطبيق متخصص لمفهوم الأصل العام الذي يشمل كل شيء ملموس أو غير ملموس ذي قيمة.
- ◀ وظيفته تمثيل محل الحماية الذي يبدأ منه تحليل الخطر وتحديد الأثر.
- ◀ **الوظيفة:** تحديد ما يحتاج إلى حماية.
- ◀ **المسؤوليات:** جرد الأصل، تصنيف البيانات، تعيين المالك، تحديد متطلبات الحماية، مراجعة التغيرات.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022، ECC-2:2024.
- ◀ **الأجهزة:** سجل الأصول، سجل تصنيف البيانات، نظام إدارة أصول.
- ◀ **وحدة البيانات:** بطاقة أصل تتضمن الاسم والنوع والمالك والقيمة والتصنيف والعلاقة بالخدمة.
- ◀ **مثال:** ملف رواتب الموظفين وبيانات الهوية أصل معلوماتي ذو تصنيف سري، ويرتبط بخدمة الموارد البشرية وبالواقعة IR-2026-05-017.



الأصل المعلوماتي (Information Asset) (الشكل)

SLIDE 11 • INFORMATION ASSET

الأصل المعلوماتي



الأجهزة والأدوات

- سجل الأصول
- سجل تصنيف البيانات
- نظام إدارة أصول

البروتوكولات والمعايير

- ISO/IEC 27001:2022
- ECC-2:2024

الوظائف الرئيسية

- تحديد ما يحتاج إلى حماية
- جرد الأصل
- تصنيف البيانات
- تعيين المالك
- تحديد متطلبات الحماية

ملف رواتب الموظفين وبيانات الهوية أصل معلوماتي ذو تصنيف سري، ويرتبط بخدمة الموارد البشرية وبالواقعة IR-2026-05-017.

الأصل المعلوماتي هو المعلومات أو السجلات أو الأنظمة أو الخدمات المرتبطة بالمعلومات التي تكون ذات قيمة للجهة.



مالك الأصل (Asset Owner)

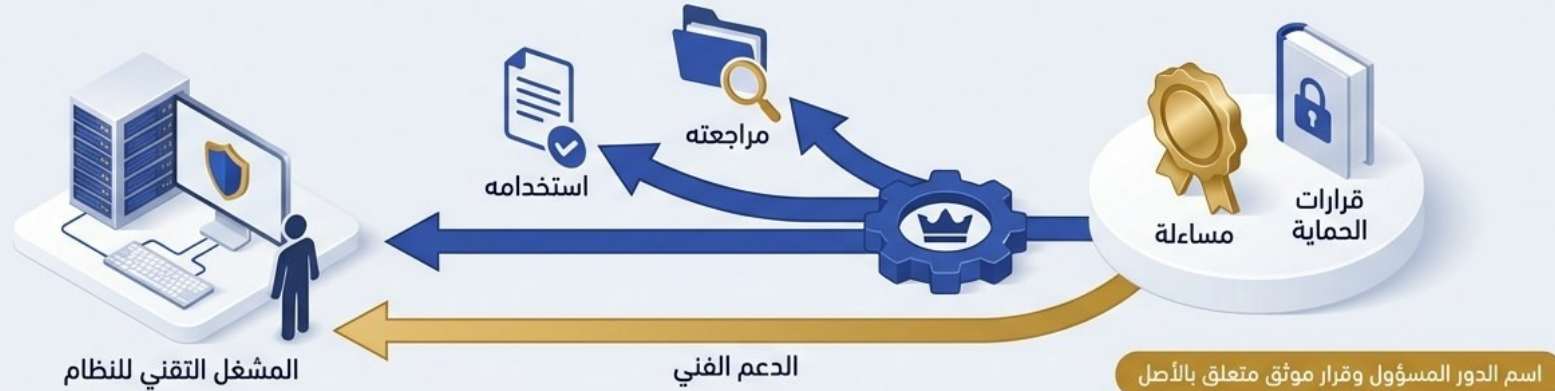
- ◀ مالك الأصل هو دور تنظيمي مسؤول عن قرارات حماية الأصل واستخدامه ومراجعته، ولا يلزم أن يكون هو المشغل التقني للنظام.
- ◀ وظيفته تحديد جهة المساءلة عن قرار الحماية والمعالجة والمتابعة.
- ◀ **الوظيفة:** تعيين المساءلة عن الأصل.
- ◀ **المسؤوليات:** اعتماد التصنيف، مراجعة الوصول، قبول أو تصعيد الخطر، متابعة الإجراء، توفير الأدلة.
- ◀ **البروتوكولات والمعايير:** الحوكمة، نظام إدارة أمن المعلومات، ضوابط ECC.
- ◀ **الأجهزة:** سجل الأصول، مصفوفة مسؤوليات، سجل مخاطر.
- ◀ **وحدة البيانات:** اسم الدور المسؤول وقرار موثق متعلق بالأصل.
- ◀ **مثال:** مدير الموارد البشرية مالك وظيفي لبيانات الموظفين، بينما توفر إدارة التقنية التشغيل والدعم الفني للنظام الذي يخزنها.



مالك الأصل (Asset Owner) (الشكل)

SLIDE 12 · ASSET OWNER

مالك الأصل



الأجهزة والأدوات

- سجل الأصول
- مصفوفة مسؤوليات
- سجل مخاطر

البروتوكولات والمعايير

- الحوكمة
- نظام إدارة أمن المعلومات
- ضوابط ECC

الوظائف الرئيسية

- تعيين المساءلة عن الأصل
- اعتماد التصنيف
- مراجعة الوصول
- قبول أو تصعيد الخطر
- متابعة الإجراء

مدير الموارد البشرية مالك وظيفي لبيانات الموظفين، بينما توفر إدارة التقنية التشغيل والدعم الفني للنظام الذي يخزنها.

مالك الأصل هو دور تنظيمي مسؤول عن قرارات حماية الأصل واستخدامه ومراجعته، ولا يلزم أن يكون هو المشغل التقني للنظام.



ملخص الوحدة الأولى ونقطة التحقق



- تميزت بين الخطر القانوني المرتبط بالتزامات أو حقوق، والخطر الأخلاقي المرتبط بالثقة والعدالة، والخطر التشغيلي المرتبط بالخدمة والعمليات.
- حددت أيضاً أن الأصل المعلوماتي هو محل التحليل، وأن مالك الأصل مسؤول عن قرارات حمايته ومتابعتها.
- أكمل نقطة التحقق في المنصة قبل الانتقال، ثم احتفظ بسبب التصنيف الذي كتبه في النشاط بوصفه دليلاً على الإكمال.



سجل المخاطر (Risk Register)

- ◀ سجل المخاطر وثيقة منظمة توثق الأخطار وتقديراتها ومعالجاتها ومسؤوليها وحالاتها.
- ◀ وظيفته تحويل إدارة المخاطر إلى عملية قابلة للتتبع والمراجعة.
- ◀ **الوظيفة:** تجميع قرارات المخاطر ومتابعتها.
- ◀ **المسؤوليات:** إدخال الخطر، ربطه بالأصل، تقدير الاحتمالية والأثر، تعيين المالك، تحديث الحالة.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-30 Rev. 1, ISO/IEC 27001:2022.
- ◀ **الأجهزة:** جدول سجل مخاطر، منصة حوكمة ومخاطر والتزام، لوحة متابعة.
- ◀ **وحدة البيانات:** صف سجل يحتوي الأصل والخطر والاحتمالية والأثر والمستوى والمعالجة والمالك والحالة.
- ◀ **مثال:** السجل R-2026-05 يربط ملف الرواتب بخطر الإرسال غير المقصود، ويعين مسؤول الامتثال مالكا للمتابعة.



سجل المخاطر (Risk Register) (الشكل)

SLIDE 13 · RISK REGISTER

سجل المخاطر



الأجهزة والأدوات

- جدول سجل مخاطر
- منصة حوكمة ومخاطر والتزام
- لوحة متابعة

البروتوكولات والمعايير

- NIST SP 800-30 Rev. 1
- ISO/IEC 27001:2022

الوظائف الرئيسية

- تجميع قرارات المخاطر ومتابعتها
- إدخال الخطر
- ربطه بالأصل
- تقدير الاحتمالية والأثر
- تعيين المالك

السجل R-2026-05 يربط ملف الرواتب بخطر الإرسال غير المقصود، ويعين مسؤول الامتثال مالكا للمتابعة.

سجل المخاطر وثيقة منظمة توثق الأخطار وتقديراتها ومعالجاتها ومسؤوليها وحالاتها. وظيفته تحويل إدارة المخاطر إلى عملية قابلة للتتبع والمراجعة.

سجل مخاطر قانونية وأخلاقية وتشغيلية



المستند: سجل المخاطر القانونية والأخلاقية

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستفيدين
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

سجل المخاطر القانونية والأخلاقية

الفترة: مايو 2026 | التقييم نوعي وفق شهية المخاطر المعتمدة في الشركة

معرف الخطر	الأصل المعلوماتي	وصف الخطر أو السيناريو	فئة الخطر	الاحتمالية	الأثر	مستوى الخطر	استراتيجية المعالجة	المالك المسؤول	دليل المتابعة
R-2026-05	ملف رواتب الموظفين وبيانات الهوية	إرسال ملف يحتوي على بيانات شخصية ومالية إلى المورد (مشأة سعودية) بنسب الإكمال التلقائي للبريد الإلكتروني.	قانوني وأخلاقي	متوسطة	مرتفع	مرتفع	تخفيف	مسؤول الامتثال	تأكيد حذف المستلم وسجل مراجعة قاعدة منع فقدان البيانات
R-2026-06	عروض أسعار الموردين والوثائق التعاقدية	استمرار صلاحيات موظف منقوّل من إدارة المشتريات إلى إدارة التسويق الرقمي لمدة شهرين بعد النقل.	قانوني وأخلاقي وتشغيلي	مرتفع	مرتفع	خرج	تخفيف	مدير تقنية المعلومات بالتنسيق مع الموارد البشرية	تقرير مراجعة صلاحيات المنقولين وسجل إكمال الوصول
R-2026-07	حساب مشرف لخدمة المستفيدين	مشاركة ثلاثة موظفين بيانات دخول حساب ذي صلاحيات مرتفعة لتسريع معالجة الطلبات.	أخلاقي وتشغيلي	متوسطة	مرتفع	مرتفع	تجنب	مسؤول أمن المعلومات	إلغاء الحساب المشترك وإنشاء حسابات فردية قائمة على الدور
R-2026-08	شاشات تشغيل منصة الخدمات الرقمية	ظهور أرقام هواتف وبيانات طلبات مستفيدين في فيديو داخلي نشره موظف على منصة تواصل اجتماعي.	قانوني وأخلاقي	متوسطة	مرتفع	مرتفع	تخفيف	مدير التواصل المؤسسي	إثبات حذف المحتوى وسجل اعتماد المحتوى الإعلامي
R-2026-09	دليل إجراءات الاستجابة للحوادث	عدم اكتمال توثيق بعض حوادث البريد الإلكتروني منخفضة الأثر في سجل موحّد.	تشغيلي وقانوني	متوسطة	متوسط	متوسط	تخفيف	مسؤول الامتثال	نتيجة مراجعة داخلية شهرية لسجل الحوادث

لا تستخدم هذه السجلات نسباً رقمية أو تقديرات مالية، يعاد تقييم مستوى الخطر بعد تحقق دليل المعالجة وقبل إكمال السجل.

مستند تعليمي إداري، الأسماء والأرقام غير حقيقية

- أقرأ صفوف سجل المخاطر بالترتيب.
- ابدأ بمعرف الخطر والأصل المتأثر، ثم أقرأ السيناريو وفئة الخطر.
- بعد ذلك قارن الاحتمالية بالأثر لتحديد مستوى الخطر.
- أخيراً تحقق من استراتيجية المعالجة والمالك ودليل المتابعة.
- يظهر السجل أن R-2026-06 خرج، بينما R-2026-09 متوسط وفق التقييم النوعي المعتمد.



خرق السياسة (Policy Breach)

- ◀ خرق السياسة هو عدم التزام سلوك أو ممارسة فعلية بما تقرره سياسة أو إجراء أو معيار داخلي معتمد.
- ◀ وظيفته إطلاق مسار التوثيق والتحليل والتصحيح والتحسين.
- ◀ **الوظيفة:** بدء الاستجابة المنظمة للمخالفة.
- ◀ **المسؤوليات:** تسجيل الواقعة، الاحتواء بحسب الصلاحية، إخطار المالك، تحليل السبب، تعيين إجراء تصحيحي.
- ◀ **البروتوكولات والمعايير:** سياسة أمن المعلومات، ECC-2:2024، نظام إدارة أمن المعلومات.
- ◀ **الأجهزة:** نموذج بلاغ، سجل مخالفة، خطة إجراء تصحيحي.
- ◀ **وحدة البيانات:** تقرير خرق سياسة وحالة متابعة.
- ◀ **مثال:** إرسال ملف يحتوي بيانات رواتب وبيانات هوية إلى المورد بسبب الإكمال التلقائي للبريد الإلكتروني يمثل خرقاً للسياسات ذات الصلة بسرية البيانات والبريد الإلكتروني.



خرق السياسة (Policy Breach) (الشكل)

SLIDE 15 · POLICY BREACH

خرق السياسة



الأجهزة والأدوات

- نموذج بلاغ
- سجل مخالفة
- خطة إجراء تصحيحي

البروتوكولات والمعايير

- سياسة أمن المعلومات
- ECC-2:2024
- نظام إدارة أمن المعلومات

الوظائف الرئيسية

- بدء الاستجابة المنظمة للمخالفة
- تسجيل الواقعة
- الاحتواء بحسب الصلاحية
- إخطار المالك
- تحليل السبب

إرسال ملف يحتوي بيانات رواتب وبيانات هوية إلى المورد بسبب الإكمال التلقائي للبريد الإلكتروني يمثل خرقاً للسياسات ذات الصلة بسرية البيانات والبريد الإلكتروني

خرق السياسة هو عدم التزام سلوك أو ممارسة فعلية بما تقرره سياسة أو إجراء أو معيار داخلي معتمد. وظيفته إطلاق مسار التوثيق والتحليل والتصحيح والتحسين.



مخالفة الخصوصية (Privacy Violation)

- ◀ مخالفة الخصوصية هي معالجة أو إفصاح أو تغيير لغرض معالجة بيانات شخصية على غير المسوغ أو الضوابط المنطبقة.
- ◀ وظيفتها تمييز الوقائع التي تمس حقوق صاحب البيانات أو التزامات جهة التحكم.
- ◀ **الوظيفة:** حماية حقوق صاحب البيانات.
- ◀ **المسؤوليات:** التحقق من الغرض، التحقق من الموافقة أو المسوغ، الحد من الإفصاح، التصعيد، توثيق القرار.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، سياسة الخصوصية، سجل المعالجة.
- ◀ **الأجهزة:** سجل معالجة بيانات، نموذج بلاغ داخلي، سجل قرارات.
- ◀ **وحدة البيانات:** وصف الواقعة والبيانات المتأثرة والمسؤول ومسار التصعيد.
- ◀ **مثال:** استخدام بيانات جُمعت لغرض خدمة في نشاط تسويقي غير معلن دون مسوغ مناسب يمثل مخالفة خصوصية محتملة.



مخالفة الخصوصية (Privacy Violation) (الشكل)

SLIDE 16 • PRIVACY VIOLATION

مخالفة الخصوصية



وصف الواقعة والبيانات المتأثرة والمسؤول ومسار

الأجهزة والأدوات

- سجل معالجة بيانات
- نموذج بلاغ داخلي
- سجل قرارات

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- سياسة الخصوصية
- سجل المعالجة

الوظائف الرئيسية

- حماية حقوق صاحب البيانات
- التحقق من الغرض
- التحقق من الموافقة أو المسوغ
- الحد من الإفصاح
- التصعيد

استخدام بيانات جُمعت لغرض خدمة في نشاط تسويقي غير معلن دون مسوغ مناسب يمثل مخالفة خصوصية محتملة

مخالفة الخصوصية هي معالجة أو إفصاح أو تغيير لغرض معالجة بيانات شخصية على غير المسوغ أو الضوابط المنطبقة



- ◀ الأثر القانوني هو نتيجة نظامية أو تنظيمية محتملة قد تترتب على واقعة مخالفة.
- ◀ وظيفته دعم ترتيب أولوية التصعيد وطلب الرأي المختص دون تحويل التقدير التعليمي إلى حكم قانوني نهائي.
- ◀ **الوظيفة:** دعم قرار الإحالة المنظمة.
- ◀ **المسؤوليات:** وصف الوقائع، عدم الجزم بالتكليف، الإحالة للمختص، حفظ السجلات، متابعة القرار.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، نظام مكافحة جرائم المعلوماتية.
- ◀ **الأجهزة:** تقرير واقعة، سجل أدلة، سجل تصعيد.
- ◀ **وحدة البيانات:** تقدير أثر قانوني أولي غير ملزم قانونياً.
- ◀ **مثال:** في IR-2026-05-017، يتعلق الأثر المحتمل بالتزامات حماية البيانات الشخصية وسرية بيانات الموظفين، ولذلك يحال المسار إلى المسؤولين المختصين.



الأثر القانوني (Legal Impact) (الشكل)

SLIDE 17 · LEGAL IMPACT

الأثر القانوني



الأجهزة والأدوات

- تقرير واقعة
- سجل أدلة
- سجل تصعيد

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- نظام مكافحة جرائم المعلوماتية

الوظائف الرئيسية

- دعم قرار الإحالة المنظمة
- وصف الوقائع
- عدم الجزم بالتكليف
- الإحالة للمختص
- حفظ السجلات

في IR-2026-05-017، يتعلق الأثر المحتمل بالتزامات حماية البيانات الشخصية وسرية بيانات الموظفين، ولذلك يحال المسار إلى المسؤولين المختصين.

الأثر القانوني هو نتيجة نظامية أو تنظيمية محتملة قد تترتب على واقعة مخالفة



- ◀ الأثر الأخلاقي هو نتيجة تمس الثقة أو الخصوصية أو العدالة أو كرامة صاحب البيانات أو نزاهة المؤسسة.
- ◀ وظيفته كشف الأضرار التي قد لا تظهر من الالتزام الشكلي بالنظام فقط.
- ◀ **الوظيفة:** إظهار ضرر القرار على الثقة.
- ◀ **المسؤوليات:** تحديد أصحاب المصلحة، وصف الضرر، مقارنة البدائل، توثيق المبرر، اقتراح تخفيف.
- ◀ **البروتوكولات والمعايير:** مدونة أخلاقيات، سياسة خصوصية، سياسة استخدام مقبول.
- ◀ **الأجهزة:** سجل قرار أخلاقي، قائمة تحقق للخصوصية.
- ◀ **وحدة البيانات:** تحليل أثر أخلاقي وقرار مهني مبرر.
- ◀ **مثال:** مشاركة لقطة شاشة تحتوي على بيانات غير لازمة لغرض العمل قد تقلل ثقة المستفيدين، حتى لو كان هدف التواصل داخل الفريق مشروعاً.



الأثر الأخلاقي (Ethical Impact) (الشكل)

SLIDE 18 · ETHICAL IMPACT

الأثر الأخلاقي



الأجهزة والأدوات

- سجل قرار أخلاقي
- قائمة تحقق للخصوصية

البروتوكولات والمعايير

- مدونة أخلاقيات
- سياسة خصوصية
- سياسة استخدام مقبول

الوظائف الرئيسية

- إظهار ضرر القرار على الثقة
- تحديد أصحاب المصلحة
- وصف الضرر
- مقارنة البدائل
- توثيق المبرر

مشاركة لقطة شاشة تحتوي على بيانات غير لازمة لغرض العمل قد تقلل ثقة المستخدمين، حتى لو كان هدف التواصل داخل الفريق مشروعاً.

الأثر الأخلاقي هو نتيجة تمس الثقة أو الخصوصية أو العدالة أو كرامة صاحب البيانات أو نزاهة المؤسسة.



شركة الحلول التقنية والخدمات الرقمية

إدارة المنتجات التعليمية وتقديم الخدمات الرقمية للمستفيدين

جاري: المملكة العربية السعودية

الرقم المبرسي: 3000000000000000 - السجل التجاري: 1010000000

طابع: 0500000000

تمتدح: تقرير واقعة خرق سياسة أمنية

شركة الحلول التقنية والخدمات الرقمية

إدارة المنتجات التعليمية وتقديم الخدمات الرقمية للمستفيدين

جاري: المملكة العربية السعودية

الرقم المبرسي: 3000000000000000 - السجل التجاري: 1010000000

طابع: 0500000000

رقم التقرير:

تاريخ الإبلاغ:

وقت اكتشاف الواقعة:

مصدر الإبلاغ:

نوع الواقعة:

السياسة ذات الصلة:

وصف الواقعة:

الأصل المعلوماتي المتأثر:

تصنيف البيانات:

نطاق التعرض المعروف:

الأثر القانوني المحتمل:

الأثر الأخلاقي المحتمل:

إجراءات الاحتواء المنفذة:

الأدلة المحفوظة:

التقييم النوعي الأولي:

الإجراء التصحيحي المقترح:

الإجراء الوقائي المقترح:

مالك المتابعة:

تاريخ المراجعة التالية:

مراجع سجل المخاطر:

هذا التقرير أُلِيَ ويعتمد على الواقع والأدلة المتاحة وقت الإبلاغ. تحفظ الأدلة وفق ضوابط الوصول المفيد وسجل الحفظ المعتمد في الشركة.

مقدم الطلب: _____

المسؤول: _____

الامتثال: _____

مستند تحليل المخاطر: الاسم والرقم غير مطبوعة

- ◀ **المعطيات:** ورد بلاغ من إدارة الموارد البشرية عن إرسال غير مقصود لملف يحتوي على مسير رواتب وبيانات اتصال وبيانات هوية لموظفين.
- ◀ وصل البريد إلى مستلم واحد غير مقصود خارج نطاق الشركة.
- ◀ المطلوب هو تعبئة نموذج التقرير بوقائع ثابتة، ثم تسجيل الأثر والإجراءات ومرجع سجل المخاطر من دون افتراضات إضافية.

الخطوة 1 من 4: تسجيل بيانات البلاغ الأساسية



شركة الحلول التقنية والخدمات الرقمية

إدارة المصنّات التعليمية والتدعيم الخدمات الرقمية للمستفيدين
جازان، المملكة العربية السعودية
الرقم القسري: 1010000003 - السجل التجاري: 3000000000000000
هاتف: 0500000000

النموذج: تقرير واقعة خرق سياسة أمنية

رقم التقرير: IR-2026-05-017

تاريخ الإبلاغ: 2026-05-14

وقت اكتشاف الواقعة: 10:35

مصدر الإبلاغ: إدارة الموارد البشرية

نوع الواقعة: إرسال غير مقصود لبيانات شخصية عبر البريد الإلكتروني

السياسة ذات الصلة:

وصف الواقعة:

الأصل المعلوماتي المتأثر:

تصنيف البيانات:

نطاق التعرض المعروف:

الأثر القانوني المحتمل:

الأثر الأخلاقي المحتمل:

إجراءات الاحتواء المنفذة:

الفترة المحفوظة:

التقييم النوعي الأولي:

الإجراء التصحيحي المقترح:

الإجراء الوقائي المقترح:

مالك المتابعة:

تاريخ المراجعة التالية:

موقع سجل المخاطر:

هذا التقرير لي يعتمد على الواقع والأدلة المتاحة وقت الإبلاغ. تحفظ الآلة و/أو صواب الوصول المقيد وسجل الحفظ المتعدد في الشركة.

مقدم الطلب.....

المسؤول.....

الامتياز.....

مستند شخصي: الوثائق الأساسية والأرقام غير دقيقة

- ◀ دون رقم التقرير IR-2026-05-017 وتاريخ الإبلاغ 2026-05-14 ووقت الاكتشاف 10:35 ومصدره إدارة الموارد البشرية ونوع الواقعة كما وردت في معطيات البلاغ.
- ◀ تطبق هنا قاعدة فصل الوقائع المثبتة عن التحليل أو اللوم.
- ◀ الناتج الجزئي هو تعريف واقعة قابل للتتبع يحدد ما حدث ومتى اكتشف ومن أبلغ عنه، قبل تقدير الأثر أو اختيار المعالجة.

- ◀ تدون السياسات والأصل والتصنيف ونطاق التعرض من وصف البلاغ المرفق في المعطيات، لا من افتراضات لاحقة.
- ◀ تطبق قاعدة تقييد نطاق التعرض بالوقائع المثبتة، ولذلك يسجل وصول الرسالة إلى مستلم واحد غير مقصود فقط، مع عدم ثبوت إعادة توجيهها أو تنزيل مرفقاتها.
- ◀ **الناتج الجزئي يربط التقرير بملف الرواتب المصنف سرياً وبالسياسات ذات الصلة.**



شركة الحلول التقنية والخدمات

إدارة الصمت التقنية وتقديم الخدمات الرقمية للمستفيدين
دارين - المملكة العربية السعودية
رقم التسجيل: 3000000000000 - القيد التجاري: 1010000000
هاتف: 0550000000

تقرير واقعة خرق سياسة أمنية

المواضع: تقرير واقعة خرق سياسة أمنية

رقم التقرير: IR-2026-05-017

تاريخ الإبلاغ: 2026-05-14

وقت اكتشاف الواقعة: 10:35

مصدر الإبلاغ: إدارة الموارد البشرية

نوع الواقعة: إرسال غير مقصود لبيانات شخصية عبر البريد الإلكتروني

السياسة ذات الصلة: سياسة أمن المعلومات وسياسة حماية البيانات الشخصية وسياسة الاستخدام المقبول للبريد الإلكتروني

وصف الواقعة: أرسل موظف من إدارة الموارد البشرية رسالة بريد إلكتروني إلى المورد (مشتأة سعودية) تضمنت ملحقاً مرفقاً يحتوي على مدير زبائن وبيانات اتصال وميانات هوية الموظفين. وقع الإرسال بسبب اختيار عنوان غير صحيح من قائمة الإكمال التلقائي.

الأصل للمعلومات المتأثرة: ملف زبائن الموظفين وبياناتهم الشخصية المخزنة في نظام الموارد البشرية

تصنيف البيانات: سرية، بيانات شخصية وبيانات مالية داخلية

نطاق التعرض المتوقعة: وصلت الرسالة إلى مستلم واحد غير مقصود خارج نطاق الشركة، ولم يثبت حتى وقت التقرير إتفاقة ونهجها أو تنزيل مرفعاتها إلى طرف آخر.

الأثر القانوني المحتمل: إتفاقة محتملة لإجراءات حماية البيانات الشخصية وسياسات الشركة المتعلقة بسرية بيانات الموظفين

الأثر الأخلاقي المحتمل: إتفاقة بسرية معلومات الموظفين واقعة المهنية في معالجة بياناتهم

إجراءات التخاطة المتخذة: تم التواصل مع المستلم فوراً بطلب كتابي لحذف الرسالة والعرفق وعدم مشاركتها، وطلب تأكيد مكتوب بالتألف. كما تم تعطيل رابط المشاركة المرتبط بالملف والتخفي من سجل الإرسال

الألفة المحفوظة: نسخة من الرسالة المرسلة. سجل وقت الإرسال، تأكيد الحذف الصادر من المستلم، ونسخة مفيدة الوصول من الملف المتأثر

التقييم النوعي الأولي: إتفاقية متوسطة والأثر مرفف، ولذلك يصنف مستوى الخطر مرفف

الإجراء التصحيحي المقترح:

الإجراء الوقائي المقترح:

مالك المتابعة:

تاريخ المراجعة التالية:

مراجع سجل المخاطن:

هذا التقرير أُقِدَ ويحتوي على الوقائع والأدلة والمصانة وفق الإلغاف لحفظ الألفة وفق مواد قانون الوصول وحصل الحفظ المعتمد في الشركة

اللائحة

مستند تعليمي إداري - لأقسام والأقسام غير تعليمية

المسؤول

مقدم الطلب



مستند رقم: ١٠٢٣ - التاريخ: ١٥/٠٤/٢٠٢٤



- ◀ النموذج المكتمل يحول الواقعة من وصف عام إلى تقرير قابل للمراجعة.
- ◀ يربط التقرير بين الأصل المتأثر، والسياسات ذات الصلة، والأثر القانوني والأخلاقي، وإجراءات الاحتواء، والأدلة المحفوظة، وخطة المتابعة.
- ◀ النتيجة الرئيسية هي تسجيل مستوى خطر مرتفع وربطه بمرجع سجل المخاطر R-2026-05 وإجراء تصحيحي محدد ومسؤول متابعة.



ملخص الوحدة الثانية ونقطة التحقق



حلت خرق السياسة بتسجيل الوقائع المثبتة، وتحديد الأصل والبيانات والسياسات ذات الصلة، ثم تقييد نطاق التعرض وحفظ الأدلة.

ربطت الأثر المحتمل بإجراءات احتواء وتصحيح ووقاية ومالك متابعة. أكمل نقطة التحقق في المنصة قبل الانتقال، وتأكد أن تقريرك يفرق بين حقيقة مثبتة وتقدير أولي أو إجراء مقترح.

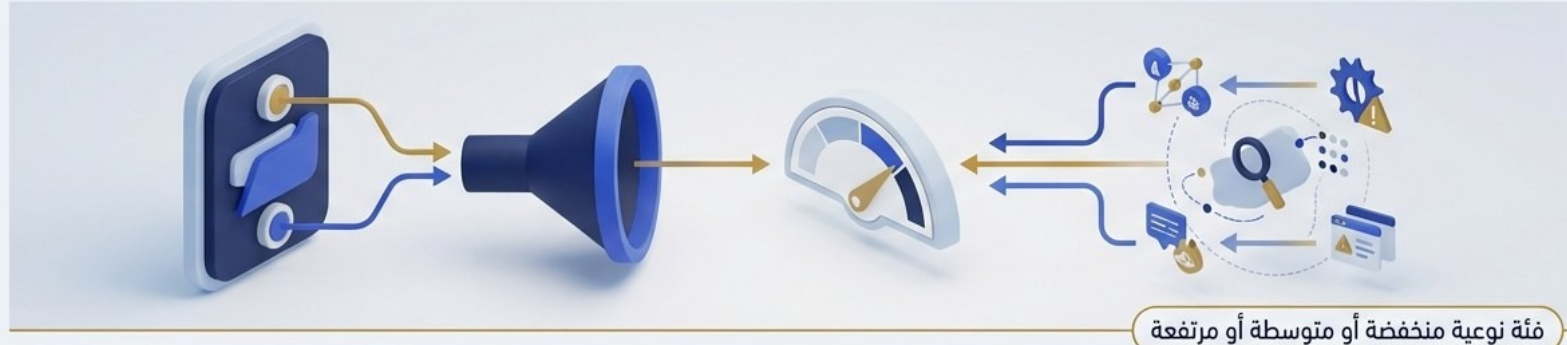


- ◀ الاحتمالية هي تقدير إمكان تحقق حدث تهديد أو سيناريو خطر في السياق محل الدراسة.
- ◀ وظيفتها تقديم أحد مدخلي تحديد مستوى الخطر.
- ◀ **الوظيفة:** تقدير إمكان تحقق السيناريو.
- ◀ **المسؤوليات:** تحديد أساس التقدير، استخدام فئات نوعية، توثيق الافتراضات، مراجعة التقدير عند تغير السياق.
- ◀ **البروتوكولات والمعايير:** منهجية تقييم المخاطر في NIST SP 800-30 Rev. 1.
- ◀ **الأجهزة:** مصفوفة مخاطر، سجل مخاطر، قائمة سيناريوهات.
- ◀ **وحدة البيانات:** فئة نوعية منخفضة أو متوسطة أو مرتفعة.
- ◀ **مثال:** تسجل الواقعة R-2026-05 باحتمالية متوسطة لأن الإكمال التلقائي يمثل نقطة ضعف قائمة في السياق، مع ثبوت وصول الرسالة إلى مستلم غير مقصود وعدم ثبوت إعادة توجيهها وقت التقرير. وقوع الواقعة دليل على وجود نقطة ضعف، لكنه لا يحدد الفئة وحده.



SLIDE 25 · LIKELIHOOD

الاحتمالية



فئة نوعية منخفضة أو متوسطة أو مرتفعة

الأجهزة والأدوات

- مصفوفة مخاطر
- سجل مخاطر
- قائمة سيناريوهات

البروتوكولات والمعايير

- منهجية تقييم المخاطر في NIST SP 800-30 Rev. 1

الوظائف الرئيسية

- تقدير إمكان تحقق السيناريو
- تحديد أساس التقدير
- استخدام فئات نوعية
- توثيق الافتراضات
- مراجعة التقدير عند تغير السياق

تسجل الواقعة R-2026-05 باحتمالية متوسطة لأن الإكمال التلقائي يمثل نقطة ضعف قائمة في السياق، مع ثبوت وصول الرسالة إلى مستلم غير مقصود وعدم ثبوت إعادة توجيهها وقت التقرير.

الاحتمالية هي تقدير إمكان تحقق حدث تهديد أو سيناريو خطر في السياق محل الدراسة. وظيفتها تقديم أحد مدخلي تحديد مستوى الخطر.



- ◀ الأثر هو حجم النتيجة المحتملة إذا تحقق حدث الخطر على البيانات أو الخدمة أو المؤسسة أو الأفراد.
- ◀ وظيفته تحديد أولوية الخطر مع الاحتمالية.
- ◀ **الوظيفة:** تقدير نتيجة تحقق الخطر.
- ◀ **المسؤوليات:** تحديد الأصل والخدمة المتأثرة، وصف النتائج، مراعاة الأثر على الأفراد، مراجعة التقدير.
- ◀ **البروتوكولات والمعايير:** عملية تقييم المخاطر، ISO/IEC 27001:2022.
- ◀ **الأجهزة:** جدول أثر، مصفوفة مخاطر، سجل حادث.
- ◀ **وحدة البيانات:** فئة أثر منخفض أو متوسط أو مرتفع.
- ◀ **مثال:** أثر R-2026-05 مرتفع لأن الملف يتضمن بيانات هوية وبيانات مالية داخلية لموظفين، ويرتبط بسرية البيانات والثقة المهنية ومتطلبات حماية البيانات الشخصية.



SLIDE 26 · IMPACT

الأثر



الأجهزة والأدوات

- جدول أثر
- مصفوفة مخاطر
- سجل حادث

البروتوكولات والمعايير

- عملية تقييم المخاطر
- ISO/IEC 27001:2022

الوظائف الرئيسية

- تقدير نتيجة تحقق الخطر
- تحديد الأصل والخدمة المتأثرة
- وصف النتائج
- مراعاة الأثر على الأفراد
- مراجعة التقدير

أثر R-2026-05 مرتفع لأن الملف يتضمن بيانات هوية وبيانات مالية داخلية لموظفين، ويرتبط بسرية البيانات والثقة المهنية ومتطلبات حماية البيانات الشخصية.

الأثر هو حجم النتيجة المحتملة إذا تحقق حدث الخطر على البيانات أو الخدمة أو المؤسسة أو الأفراد. وظيفته تحديد أولوية الخطر مع الاحتمالية.



- ◀ مستوى المخاطر هو نتيجة تصنيفية تجمع الاحتمالية والأثر لترتيب أولويات المخاطر.
- ◀ وظيفته دعم قرار المعالجة والتصعيد وتوزيع المسؤوليات.
- ◀ **الوظيفة:** ترتيب أولوية التعامل مع الخطر.
- ◀ **المسؤوليات:** تطبيق منهج موحد، توثيق التصنيف، اعتماد مستوى الخطر، إعادة التقويم بعد المعالجة.
- ◀ **البروتوكولات والمعايير:** منهجية تقييم المخاطر، نظام إدارة أمن المعلومات.
- ◀ **الأجهزة:** مصفوفة مخاطر نوعية، سجل مخاطر.
- ◀ **وحدة البيانات:** مستوى منخفض أو متوسط أو مرتفع أو حرج.
- ◀ **مثال:** يصنف R-2026-06 حرجاً لأن الاحتمالية مرتفعة والأثر مرتفع بسبب استمرار وصول موظف منقول إلى عروض أسعار الموردين والوثائق التعاقدية.



مستوى المخاطر (Risk Level) (الشكل)

SLIDE 27 · RISK LEVEL

مستوى المخاطر



الأجهزة والأدوات

- مصفوفة مخاطر نوعية
- سجل مخاطر

البروتوكولات والمعايير

- منهجية تقييم المخاطر
- نظام إدارة أمن المعلومات

الوظائف الرئيسية

- ترتيب أولوية التعامل مع الخطر
- تطبيق منهج موحد
- توثيق التصنيف
- اعتماد مستوى الخطر
- إعادة التقويم بعد المعالجة

يصنف R-2026-06 حرجاً لأن الاحتمالية مرتفعة والأثر مرتفع بسبب استمرار وصول موظف منقول إلى عروض أسعار الموردين والوثائق التعاقدية.

مستوى المخاطر هو نتيجة تصنيفية تجمع الاحتمالية والأثر لترتيب أولويات المخاطر. وظيفته دعم قرار المعالجة والتصعيد وتوزيع المسؤوليات.



- ◀ مصفوفة المخاطر أداة تربط فئات الاحتمالية بفئات الأثر لإنتاج مستوى خطر وترتيب أولوية المعالجة.
- ◀ وظيفتها توحيد طريقة مقارنة السيناريوهات وتوضيح سبب ترتيبها.
- ◀ **الوظيفة:** توحيد المقارنة بين السيناريوهات.
- ◀ **المسؤوليات:** تعريف الفئات، توثيق المبررات، تجنب الدقة الزائفة، مراجعة النتائج مع المالك.
- ◀ **البروتوكولات والمعايير:** منهج تقييم المخاطر، ممارسات إدارة المخاطر.
- ◀ **الأجهزة:** جدول بيانات، سجل مخاطر، لوحة متابعة داخلية.
- ◀ **وحدة البيانات:** خلية مستوى خطر مرتبطة بسيناريو محدد.
- ◀ **مثال:** تربط المنشأة الاحتمالية المتوسطة والأثر المرتفع للواقعة R-2026-05 بمستوى خطر مرتفع وأولوية معالجة فورية.



مصفوفة المخاطر (Risk Matrix) (الشكل)





دورة إدارة المخاطر القانونية والأخلاقية



- ▶ تبدأ دورة إدارة المخاطر بتحديد الأصل المعلوماتي ومالكه، ثم وصف سيناريو الخطر والوقائع ذات الصلة.
- ▶ يقدر الفريق الاحتمالية والأثر ويحدد مستوى الخطر من المصفوفة المعتمدة.
- ▶ بعد ذلك يختار استراتيجية معالجة، ويعين المالك والدليل والموعِد.
- ▶ تنتهي الدورة بمتابعة التنفيذ وإعادة التقييم عند تغير السياق أو الضوابط.
- ▶ لا تمثل الدورة حكماً قانونياً، بل تنظيمياً تعليمياً لقرار التوثيق والتصعيد والمعالجة.



- ◀ تستخدم المصفوفة فئات نوعية لتجنب ادعاء دقة رقمية لا تسندها بيانات أو منهج معلن.
- ◀ يقرأ المتعلم الأثر والاحتمالية أولاً، ثم يحدد مستوى الخطر من تقاطعهما.
- ◀ تعتمد المؤسسة معنى الفئات وحدود التصعيد وفق حوكمتها وسياق خدماتها، ولا يحدد الموظف منفرداً مستوى القبول المؤسسي للمخاطر.

الأثر \ الاحتمالية	منخفضة	متوسطة	مرتفعة
منخفض	منخفض	منخفض	متوسط
متوسط	منخفض	متوسط	مرتفع
مرتفع	متوسط	مرتفع	حرج



نشاط تطبيقي، قراءة سجل المخاطر



- ◀ راجع السجل R-2026-06. الأصل هو عروض أسعار الموردين والوثائق التعاقدية.
- ◀ استمرت صلاحيات موظف منقول لمدة شهرين بعد النقل.
- ◀ حدد سبب كون مستوى الخطر حرجاً، ثم اقترح إجراءً تصحيحياً فورياً وإجراءً وقائياً مؤسسياً.
- ◀ اكتب اسم المالك المسؤول ودليل متابعة واحداً.
- ◀ الزمن المتوقع عشر دقائق.



- ◀ يصنف الخطر حرجاً لأن الاحتمالية مرتفعة والأثر مرتفع، ولأن الأصل يتضمن وثائق تعاقدية حساسة يمكن أن تتأثر بالوصول الزائد وتضارب المصالح.
- ◀ الإجراء التصحيحي هو سحب الصلاحيات غير اللازمة ومراجعة حسابات الموظفين المنقولين فوراً.
- ◀ والإجراء الوقائي هو ربط نظام الموارد البشرية بدورة حياة الهوية مع مراجعة شهرية للصلاحيات.
- ◀ المالك هو مدير تقنية المعلومات بالتنسيق مع الموارد البشرية.



ملخص الوحدة الثالثة ونقطة التحقق



حددت أن مستوى الخطر ينتج من تقاطع الاحتمالية والأثر في مصفوفة معتمدة، وأن المالك يوثق مبررات التقدير ويعيده عند تغير السياق.

بينت قراءة R-2026-06 أن الاحتمالية المرتفعة والأثر المرتفع ينتجان مستوى حرجاً يتطلب معالجة ومتابعة. أكمل نقطة التحقق في المنصة قبل الانتقال إلى بدائل المعالجة.



شهية المخاطر (Risk Appetite)

- ◀ شهية المخاطر هي حدود تقبل المؤسسة للمخاطر في ضوء أهدافها وحوكمتها وسياقها.
- ◀ وظيفتها تمييز المخاطر المقبولة من المخاطر التي تحتاج إلى معالجة أو تصعيد.
- ◀ **الوظيفة:** توجيه قرار القبول أو التصعيد.
- ◀ **المسؤوليات:** تحديدها قيادياً، توصيلها للمالكين، مواءمة القرارات معها، مراجعتها عند تغير السياق.
- ◀ **البروتوكولات والمعايير:** الحوكمة، إدارة المخاطر، نظام إدارة أمن المعلومات.
- ◀ **الأجهزة:** بيان شهية مخاطر، سجل قرارات، سجل استثناءات.
- ◀ **وحدة البيانات:** حد قبول أو قرار تصعيد موثق.
- ◀ **مثال:** لا يقبل قرار فردي استمرار صلاحيات زائدة على وثائق الموردين، لأن مستوى R-2026-06 حرج ويتطلب معالجة وتصعيداً ضمن الحوكمة.



شهية المخاطر (Risk Appetite) (الشكل)

SLIDE 32 · RISK APPETITE

شهية المخاطر



الأجهزة والأدوات

- بيان شهية مخاطر
- سجل قرارات
- سجل استثناءات

البروتوكولات والمعايير

- الحوكمة
- إدارة المخاطر
- نظام إدارة أمن المعلومات

الوظائف الرئيسية

- توجيه قرار القبول أو التصعيد
- تحديدها قيادياً
- توصيلها للمالكين
- مواءمة القرارات معها
- مراجعتها عند تغير السياق

لا يقبل قرار فردي استمرار صلاحيات زائدة على وثائق الموردين، لأن مستوى R-2026-06 حرج ويتطلب معالجة وتصعيداً ضمن الحوكمة.

شهية المخاطر هي حدود تقبل المؤسسة للمخاطر في ضوء أهدافها وحوكمتها وسياقها. وظيفتها تمييز المخاطر المقبولة من المخاطر التي تحتاج إلى معالجة أو تصعيد.



معالجة المخاطر (Risk Treatment)



- ◀ معالجة المخاطر هي اختيار وتنفيذ استجابة مناسبة لخطر مقدر ومقوّم.
- ◀ وظيفتها خفض الخطر أو تجنبه أو نقله أو قبوله ضمن قرار منظم.
- ◀ **الوظيفة:** تحويل التقييم إلى إجراء.
- ◀ **المسؤوليات:** تحديد الخيار، تعيين المالك، تحديد الموعد، تعريف دليل الإنجاز، إعادة تقويم الخطر.
- ◀ **البروتوكولات والمعايير:** Risk Treatment, ISO/IEC 27001:2022, ECC-2:2024.
- ◀ **الأجهزة:** خطة معالجة، سجل مخاطر، سجل إجراء تصحيحي.
- ◀ **وحدة البيانات:** إجراء معالجة مرتبط بخطر ومالك وحالة متابعة.
- ◀ **مثال:** تخفف المنشأة الخطر R-2026-05 بمراجعة إعدادات البريد وتفعيل قاعدة تمنع إرسال ملفات الهوية والرواتب إلى نطاقات خارجية دون اعتماد.



معالجة المخاطر (Risk Treatment) (الشكل)

SLIDE 33 · RISK TREATMENT

معالجة المخاطر



الأجهزة والأدوات

- خطة معالجة
- سجل مخاطر
- سجل إجراء تصحيحي

البروتوكولات والمعايير

- Risk Treatment
- ISO/IEC 27001:2022
- ECC-2:2024

الوظائف الرئيسية

- تحويل التقييم إلى إجراء
- تحديد الخيار
- تعيين المالك
- تحديد الموعد
- تعريف دليل الإنجاز

تخفف المنشأة الخطر R-2026-05 بمراجعة إعدادات البريد وتفعيل قاعدة تمنع إرسال ملفات الهوية والرواتب إلى نطاقات خارجية دون اعتماد.

معالجة المخاطر هي اختيار وتنفيذ استجابة مناسبة لخطر مقدّر ومقوّم. وظيفتها خفض الخطر أو تجنبه أو نقله أو قبوله ضمن قرار منظم.



(Risk Avoidance) تجنب المخاطر

- ◀ تجنب المخاطر هو عدم تنفيذ نشاط أو إيقافه أو تغيير تصميمه لمنع التعرض لخطر غير مقبول.
- ◀ وظيفته إزالة مصدر الخطر من نطاق العمل عندما لا تكون خيارات الضبط الأخرى مناسبة.
- ◀ **الوظيفة:** منع التعرض للخطر من المصدر.
- ◀ **المسؤوليات:** تحليل البدائل، اعتماد قرار التجنب، توثيق أثره على الخدمة، تحديث السجل.
- ◀ **البروتوكولات والمعايير:** Risk Avoidance، إدارة المخاطر.
- ◀ **الأجهزة:** سجل قرارات، سجل مخاطر، نموذج اعتماد.
- ◀ **وحدة البيانات:** قرار تجنب موثق وبديل تشغيلي إن وجد.
- ◀ **مثال:** يعالج R-2026-07 بتجنب مشاركة الحساب، عبر إيقاف حساب المشرف المشترك وإنشاء حسابات فردية قائمة على الدور بدلاً من استمرار الممارسة نفسها.



تجنب المخاطر (Risk Avoidance) (الشكل)

SLIDE 34 · RISK AVOIDANCE

تجنب المخاطر

تجنب المخاطر هو عدم تنفيذ نشاط أو إيقافه أو تغيير تصميمه لمنع التعرض لخطر غير مقبول. وظيفته إزالة مصدر الخطر من نطاق العمل عندما لا تكون خيارات الضبط الأخرى مناسبة.



قرار تجنب موثق وبدل تشغيلي إن وجد.

الأجهزة والأدوات

- سجل قرارات
- سجل مخاطر
- نموذج اعتماد

البروتوكولات والمعايير

- Risk Avoidance
- إدارة المخاطر

الوظائف الرئيسية

- منع التعرض للخطر من المصدر
- تحليل البدائل
- اعتماد قرار التجنب
- توثيق أثره على الخدمة
- تحديث السجل

يعالج R-2026-07 بتجنب مشاركة الحساب، عبر إيقاف حساب المشرف المشترك وإنشاء حسابات فردية قائمة على الدور بدلاً من استمرار الممارسة نفسها.

تجنب المخاطر هو عدم تنفيذ نشاط أو إيقافه أو تغيير تصميمه لمنع التعرض لخطر غير مقبول.



تخفيف المخاطر (Risk Mitigation)



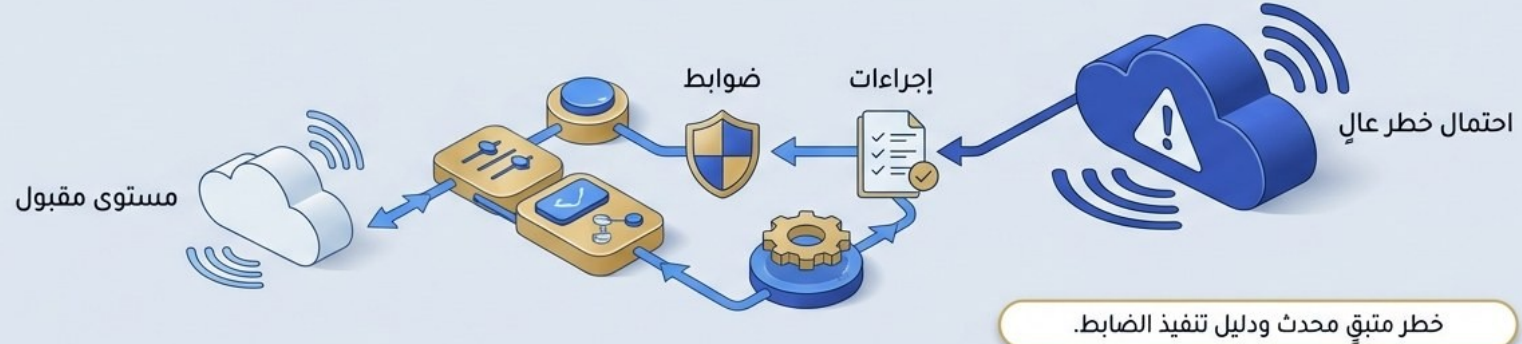
- ◀ تخفيف المخاطر هو خفض احتمال الخطر أو أثره باستخدام ضوابط أو إجراءات أو تحسينات مناسبة.
- ◀ وظيفته تقليل الخطر إلى مستوى مقبول أو أقل.
- ◀ **الوظيفة:** خفض الاحتمالية أو الأثر.
- ◀ **المسؤوليات:** اختيار ضابط مناسب، تعيين المسؤول، توثيق الدليل، قياس الفاعلية، مراجعة الخطر المتبقي.
- ◀ **البروتوكولات والمعايير:** Risk Reduction, ECC-2:2024, ISO/IEC 27001:2022.
- ◀ **الأجهزة:** سياسة، ضابط وصول، تدريب، مراجعة، خطة إجراء تصحيحي.
- ◀ **وحدة البيانات:** خطر متبقي محدث ودليل تنفيذ الضابط.
- ◀ **مثال:** تخفف المنشأة R-2026-08 بطلب حذف المحتوى، ثم اعتماد مراجعة للمحتوى الإعلامي قبل النشر وتنفيذ توعية بسياسة التصوير داخل بيئة العمل.



تخفيف المخاطر (Risk Mitigation) (الشكل)

SLIDE 35 · RISK MITIGATION

تخفيف المخاطر



الأجهزة والأدوات

- سياسة
- ضابط وصول
- تدريب
- مراجعة
- خطة إجراء تصحيحي

البروتوكولات والمعايير

- Risk Reduction
- ECC-2:2024
- ISO/IEC 27001:2022

الوظائف الرئيسية

- خفض الاحتمالية أو الأثر
- اختيار ضابط مناسب
- تعيين المسؤول
- توثيق الدليل
- قياس الفاعلية

تخفف المنشأة R-2026-08 بطلب حذف المحتوى، ثم اعتماد مراجعة للمحتوى الإعلامي قبل النشر وتنفيذ توعية بسياسة التصوير داخل بيئة العمل.

تخفيف المخاطر هو خفض احتمال الخطر أو أثره باستخدام ضوابط أو إجراءات أو تحسينات مناسبة. وظيفته تقليل الخطر إلى مستوى مقبول أو أقل.



(Risk Transfer) نقل المخاطر

- ◀ نقل المخاطر هو ترتيب توزيع بعض الآثار أو الالتزامات مع طرف آخر عبر آلية تعاقدية أو تأمينية أو خدمية مناسبة.
- ◀ وظيفته إدارة أثر محدد للخطر، ولا يعني إزالة الخطر أو المسؤولية التنظيمية تلقائياً.
- ◀ **الوظيفة:** توزيع أثر محدد مع طرف آخر.
- ◀ **المسؤوليات:** تقييم الطرف، تحديد الالتزامات، توثيق الاتفاق، متابعة الأداء، حفظ المسؤوليات النظامية.
- ◀ **البروتوكولات والمعايير:** Risk Transfer، متطلبات جهة التحكم عند اختيار جهة المعالجة.
- ◀ **الأجهزة:** عقد، اتفاقية مستوى خدمة، سجل موردين، سجل مخاطر.
- ◀ **وحدة البيانات:** قرار نقل جزئي للخطر مع التزامات متبعة.
- ◀ **مثال:** التعاقد مع جهة معالجة بيانات قد ينظم بعض المسؤوليات التعاقدية، لكنه لا يعفي جهة التحكم من التزاماتها المتعلقة بحماية البيانات الشخصية.



نقل المخاطر (Risk Transfer) (الشكل)

SLIDE 36 • RISK TRANSFER

نقل المخاطر



الأجهزة والأدوات

- عقد
- اتفاقية مستوى خدمة
- سجل موردين
- سجل مخاطر

البروتوكولات والمعايير

- Risk Transfer
- متطلبات جهة التحكم عند اختيار جهة المعالجة

الوظائف الرئيسية

- توزيع أثر محدد مع طرف آخر
- تقييم الطرف
- تحديد الالتزامات
- توثيق الاتفاق
- متابعة الأداء

التعاقد مع جهة معالجة بيانات قد ينظم بعض المسؤوليات التعاقدية، لكنه لا يعفي جهة التحكم من التزاماتها المتعلقة بحماية البيانات الشخصية.

نقل المخاطر هو ترتيب توزيع بعض الآثار أو الالتزامات مع طرف آخر عبر آلية تعاقدية أو تأمينية أو خدمة مناسبة.



قبول المخاطر (Risk Acceptance)

- ◀ قبول المخاطر قرار موثق بقبول الخطر المتبقي ضمن حدود الحوكمة والصلاحيات المعتمدة.
- ◀ وظيفته إظهار أن الخطر عولج بقرار واعٍ، لا بإهمال أو تجاهل.
- ◀ **الوظيفة:** توثيق قرار قبول الخطر المتبقي.
- ◀ **المسؤوليات:** وصف الخطر المتبقي، بيان المبرر، تحديد صاحب الاعتماد، تحديد تاريخ مراجعة، مراقبة التغير.
- ◀ **البروتوكولات والمعايير:** Risk Retention، الحوكمة، إدارة المخاطر.
- ◀ **الأجهزة:** سجل استثناءات، سجل قبول مخاطر، سجل قرارات.
- ◀ **وحدة البيانات:** قرار قبول مؤرخ ومعتمد وفق الصلاحية.
- ◀ **مثال:** يمكن قبول خطر منخفض بصورة مؤقتة بعد توثيق الضوابط القائمة وتاريخ المراجعة، لكن لا يقبل خطر R-2026-06 الحرج شفهياً أو من غير صاحب صلاحية.



قبول المخاطر (Risk Acceptance) (الشكل)

SLIDE 37 · RISK ACCEPTANCE

قبول المخاطر



الأجهزة والأدوات

- سجل استثناءات
- سجل قبول مخاطر
- سجل قرارات

البروتوكولات والمعايير

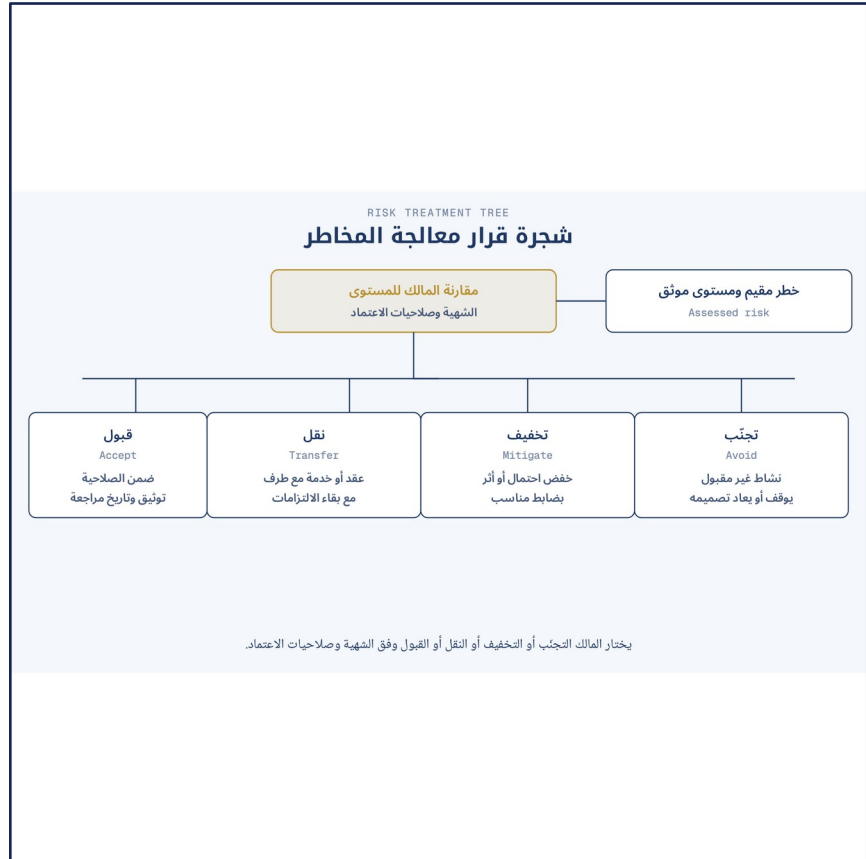
- Risk Retention
- الحوكمة
- إدارة المخاطر

الوظائف الرئيسية

- توثيق قرار قبول الخطر المتبقي
- وصف الخطر المتبقي
- بيان المبرر
- تحديد صاحب الاعتماد
- تحديد تاريخ مراجعة

يمكن قبول خطر منخفض بصورة مؤقتة بعد توثيق الضوابط القائمة وتاريخ المراجعة، لكن لا يقبل خطر R-2026-06 الحرج شفهياً أو من غير صاحب صلاحية.

قبول المخاطر قرار موثق بقبول الخطر المتبقي ضمن حدود الحوكمة والصلاحيات المعتمدة. وظيفته إظهار أن الخطر عولج بقرار واعٍ، لا بإهمال أو تجاهل.



- ◀ يبدأ القرار بخطر مقيم ومستوى موثق، ثم يقارن المالك مستوى الخطر بشهية المؤسسة وصلحيات الاعتماد.
- ◀ إذا كان النشاط غير مقبول فيوقف أو يعاد تصميمه، فتكون الاستراتيجية تجنباً.
- ◀ إذا أمكن خفض الاحتمالية أو الأثر بضابط مناسب، فتكون تخفيفاً.
- ◀ إذا نظم عقد أو خدمة أثراً محدداً مع طرف آخر، فتكون نقلاً مع بقاء الالتزامات ذات الصلة.
- ◀ وإذا بقي خطر ضمن الصلاحية، يوثق قبوله وتاريخ مراجعته.

- ◀ يختار الفريق الاستراتيجية بعد فهم الأصل والسيناريو ومستوى الخطر وشهية المؤسسة للمخاطر.
- ◀ التجنب يزيل النشاط أو يغير تصميمه.
- ◀ التخفيف يضيف ضوابط أو إجراءات.
- ◀ النقل يوزع آثاراً محددة مع طرف آخر.
- ◀ والقبول قرار موثق للخطر المتبقي ضمن الصلاحيات.
- ◀ لا تكفي تسمية الاستراتيجية من دون مالك ودليل متابعة.

الاستراتيجية	متى تستخدم	مثال من الفصل	الدليل المتوقع
التجنب	عند عدم قبول النشاط	إلغاء الحساب المشترك	حسابات فردية
التخفيف	عند إمكان خفض الخطر	مراجعة صلاحيات المنقولين	تقرير مراجعة
النقل	عند تنظيم أثر مع طرف	اتفاق مع جهة معالجة	التزام تعاقدى
القبول	للخطر المتبقي الموثق	خطر منخفض مؤقت	قرار وتاريخ مراجعة



ملخص الوحدة الرابعة ونقطة التحقق



قارنت بين التجنب الذي يزيل مصدر التعرض، والتخفيف الذي يخفض الاحتمالية أو الأثر، والنقل الذي يوزع أثراً محدداً، والقبول الذي يوثق الخطر المتبقي.

ربطت القرار بشهية المخاطر وصاحب الصلاحية ودليل المتابعة. أكمل نقطة التحقق في المنصة قبل الانتقال إلى التوثيق والإجراء التصحيحي.

نموذج خطة الإجراء التصحيحي والوقائي



شركة الحلول التقنية والخدمات الرقمية

إدارة المنتجات التعليمية وتقديم الخدمات الرقمية للمستفيدين

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

نموذج: خطة إجراء تصحيحي ووقائي

خطة إجراء تصحيحي ووقائي

رقم الخطة:CAPA-2026-05-011

مرجع الواقعة:IR-2026-05-017

مرجع الخطر:R-2026-05

تاريخ فتح الخطة:2026-05-14

وصف عدم المطابقة: تم إرسال ملف رواتب وبيانات شخصية لموظفين إلى مسلم غير مقصود خارج نطاق الشركة.

السبب الجذري المبدئي: الاعتماد على الإكمال التلقائي للبيانات الإلكتروني دون تحقق ثنائي من المسلم، مع غياب ضابط لقي بيع إرسال ملفات البيانات الحساسة إلى نطاقات خارجية.

الإجراء التصحيحي الفوري: الحصول على تأكيد مكتوب بخلاف الرسالة والمرافق من المسلم، وتعطيل رابط المشاركة وحصر الوصول إلى نسخة الملف المخوفة للأذلة.

مسؤول الإجراء التصحيحي: مسؤول الامتثال

دليل الإنغلاق التصحيحي: رسالة تأكيد الحذف وسجل تعطيل رابط المشاركة وحضر حفظ الأذلة.

الإجراء الوقائي التقني: إعداد قاعدة لمنع فقدان البيانات تية أو تمنع إرسال ملفات تضمن أرقام هوية أو بيانات رواتب إلى نطاقات بريد خارجية دون اعتماد مسؤول محول.

مالك الإجراء الوقائي التقني: مسؤول أمن المعلومات

الإجراء الوقائي البشري: تدريب تشيطي موزع لموظفي الموارد البشرية حول التحقق من المسلم وتصنيف البيانات والتعامل مع المرفقات الحساسة.

مالك الإجراء الوقائي البشري: مدير الموارد البشرية

إجراء المراجعة الداخلية: مراجعة غيبة من رسائل البريد الخارجي التي تحتوي على مرفقات مصفحة سرية والتحقق من تطبيق ضوابط الاعتماد والمعن.

مالك المراجعة الداخلية: مدير المراجعة الداخلية

تاريخ إنجاز الإجراء التصحيحي المستهدف:2026-05-16

تاريخ إنجاز الضابط التقني المستهدف:2026-05-26

تاريخ تنفيذ التدريب المستهدف:2026-05-24

تاريخ التحقق من الفاعلية:2026-06-18

معايير فاعلية المعالجة: تطوير مراجعة البريد الخارجي تطبيق قاعدة الممنع أو الاعتماد على جميع الرسائل ذات المرفقات الحساسة. وثقت سجل التدريب لإتمام الموظفين المعنيين للتدريب.

حالة الخطة: مفعومة، بانتظار التحقق من فاعلية الضوابط

لا تقبل الخطة بحدود تعيد الإنعاش. على الخطر بعد التحقق من التأهيل وتقييم المخاطر الحساسة من قبل مالك المعالجة.

مقدم الطلب

المسؤول

الامتثال

مستند تخليص الترخيص: التمسك باللائحة رقم ٢٠٢٤

- يربط النموذج الخطة CAPA-2026-05-011 بالواقعة IR-2026-05-017 وبالخطر R-2026-05. ابدأ بقراءة وصف عدم المطابقة والسبب الجذري.
- ثم ميز بين الإجراء التصحيحي الفوري والإجراءات الوقائية التقنية والبشرية.
- تحقق من تعيين المالك لكل إجراء ومن تواريخ الإنجاز ومعايير فاعلية المعالجة قبل إغلاق الخطة.



(Corrective Action) الإجراء التصحيحي

- ◀ الإجراء التصحيحي هو إجراء يعالج فجوة أو مخالفة أو سبباً مرتبطاً بخطر محدد.
- ◀ وظيفته تحويل نتائج التحليل إلى عمل قابل للمساءلة والقياس والمتابعة.
- ◀ **الوظيفة:** معالجة الفجوة أو السبب المحدد.
- ◀ **المسؤوليات:** تحديد الفجوة، تحليل السبب، تعيين المالك، تحديد الموعد، جمع دليل الإنجاز، التحقق من الفاعلية.
- ◀ **البروتوكولات والمعايير:** التحسين المستمر، نظام إدارة أمن المعلومات، ECC-2:2024.
- ◀ **الأجهزة:** خطة إجراء تصحيحي، سجل ملاحظات، سجل مخاطر.
- ◀ **وحدة البيانات:** بند إجراء يضم الخطر والسبب والإجراء والمالك والموعد والحالة والدليل.
- ◀ **مثال:** يتضمن CAPA-2026-05-011 طلب تأكيد مكتوب بحذف الرسالة وتعطيل رابط المشاركة وحصر الوصول إلى نسخة الملف المحفوظة للأدلة.



الإجراء التصحيحي (Corrective Action) (الشكل)

SLIDE 40 · CORRECTIVE ACTION

الإجراء التصحيحي



الأجهزة والأدوات

- خطة إجراء تصحيحي
- سجل ملاحظات
- سجل مخاطر

البروتوكولات والمعايير

- التحسين المستمر
- نظام إدارة أمن المعلومات
- ECC-2:2024

الوظائف الرئيسية

- معالجة الفجوة أو السبب المحدد
- تحديد الفجوة
- تحليل السبب
- تعيين المالك
- تحديد الموعد

يتضمن CAPA-2026-05-011 طلب تأكيد مكتوب بحذف الرسالة وتعطيل رابط المشاركة وحصر الوصول إلى نسخة الملف المحفوظة للأدلة.

الإجراء التصحيحي هو إجراء يعالج فجوة أو مخالفة أو سبباً مرتبطاً بخطر محدد. وظيفته تحويل نتائج التحليل إلى عمل قابل للمساءلة والقياس والمتابعة.



(Preventive Action) الإجراء الوقائي

- ◀ الإجراء الوقائي هو إجراء استباقي يهدف إلى خفض احتمال وقوع مخالفة أو حادث مستقبلي.
- ◀ وظيفته تقليل التعرض قبل تحقق الأثر.
- ◀ **الوظيفة:** منع تكرار المخالفة مستقبلاً.
- ◀ **المسؤوليات:** تحديد السيناريو، اختيار ضابط مناسب، تنفيذ الإجراء، مراقبة الفاعلية، تحديث السجل.
- ◀ **البروتوكولات والمعايير:** إدارة المخاطر، ضوابط ECC، نظام إدارة أمن المعلومات.
- ◀ **الأجهزة:** مراجعة صلاحيات، تدريب موجه، قائمة تحقق، تنبيه دوري.
- ◀ **وحدة البيانات:** إجراء وقائي ودليل متابعة.
- ◀ **مثال:** في CAPA-2026-05-011، تعد قاعدة منع فقدان البيانات والتدريب التنشيطي لموظفي الموارد البشرية إجراءين وقائيين يعالجان سبب الإرسال غير المقصود.



الإجراء الوقائي (Preventive Action) (الشكل)

SLIDE 41 · PREVENTIVE ACTION

الإجراء الوقائي



إجراء وقائي ودليل متابعة

الأجهزة والأدوات

- مراجعة صلاحيات
- تدريب موجه
- قائمة تحقق
- تنبيه دوري

البروتوكولات والمعايير

- إدارة المخاطر
- ضوابط ECC
- نظام إدارة أمن المعلومات

الوظائف الرئيسية

- منع تكرار المخالفة مستقبلاً
- تحديد السيناريو
- اختيار ضابط مناسب
- تنفيذ الإجراء
- مراقبة الفاعلية

في 011-05-2026-CAPA، تعد قاعدة منع فقدان البيانات والتدريب التنشيطي لموظفي الموارد البشرية إجراءات وقائين يعالجان سبب الإرسال غير المقصود.

الإجراء الوقائي هو إجراء استباقي يهدف إلى خفض احتمال وقوع مخالفة أو حادث مستقبلي. وظيفته تقليل التعرض قبل تحقق الأثر.



التدريب (Training)



- ◀ التدريب نشاط منظم لبناء معرفة أو مهارة مرتبطة بدور وظيفي أو مسؤولية أمنية.
- ◀ وظيفته تمكين العاملين من أداء الإجراء أو الضابط أو مسار الإبلاغ بصورة صحيحة.
- ◀ **الوظيفة:** بناء كفاءة مرتبطة بدور محدد.
- ◀ **المسؤوليات:** تحديد الفئة، تحديد المهارة، تنفيذ التدريب، توثيق الإتمام، تقويم الاحتياج المتجدد.
- ◀ **البروتوكولات والمعايير:** إدارة الأفراد، ضوابط ECC، سياسة أمن المعلومات.
- ◀ **الأجهزة:** منصة تعلم، سجل إتمام، اختبار تطبيقي، دليل إجراء.
- ◀ **وحدة البيانات:** سجل تدريب أو دليل كفاءة متعلق بدور محدد.
- ◀ **مثال:** يوجهه CAPA-2026-05-011 تدريباً تنشيطياً لموظفي الموارد البشرية حول التحقق من المستلم وتصنيف البيانات والتعامل مع المرفقات الحساسة.



التدريب (Training) (الشكل)

SLIDE 42 • TRAINING

التدريب

تمكين العاملين من أداء الإجراء أو الضابط أو مسار الإبلاغ بصورة صحيحة.



سجل تدريب أو دليل كفاءة متعلق بدور محدد.

الأجهزة والأدوات

- منصة تعلم
- سجل إتمام
- اختبار تطبيقي
- دليل إجراء

البروتوكولات والمعايير

- إدارة الأفراد
- ضوابط ECC
- سياسة أمن المعلومات

الوظائف الرئيسية

- بناء كفاءة مرتبطة بدور محدد
- تحديد الفئة
- تحديد المهارة
- تنفيذ التدريب
- توثيق الإتمام

يوجهه CAPA-2026-05-011 تدريباً تشيظياً لموظفي الموارد البشرية حول التحقق من المستلم وتصنيف البيانات والتعامل مع المرفقات الحساسة.

التدريب نشاط منظم لبناء معرفة أو مهارة مرتبطة بدور وظيفي أو مسؤولية أمنية. وظيفته تمكين العاملين من أداء الإجراء أو الضابط أو مسار الإبلاغ بصورة صحيحة.



(Awareness) التوعية

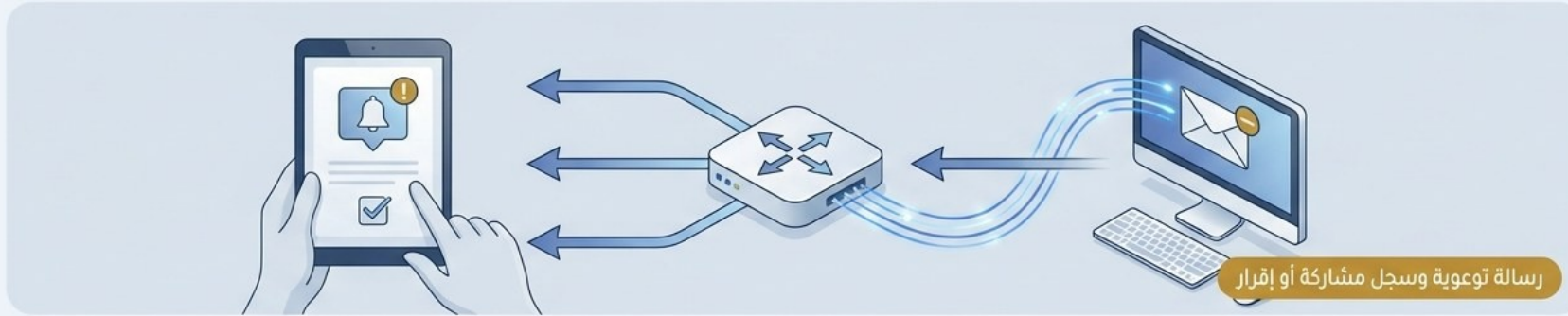


- ◀ التوعية اتصال مستمر يركز على تذكير الفئات بالسلوك المطلوب والمخاطر والسياسات.
- ◀ وظيفتها دعم الالتزام اليومي وتقليل السلوكيات غير المقصودة المخالفة.
- ◀ **الوظيفة:** تعزيز السلوك اليومي المطلوب.
- ◀ **المسؤوليات:** تحديد الرسالة، ملاءمتها للفئة، اختيار القناة، قياس المشاركة، تحديث الرسالة.
- ◀ **البروتوكولات والمعايير:** Security Awareness, ECC-2:2024، سياسات الجهة.
- ◀ **الأجهزة:** رسائل منصة داخلية، مواد مرئية، إقرار سياسة، استبيان.
- ◀ **وحدة البيانات:** رسالة توعوية وسجل مشاركة أو إقرار.
- ◀ **مثال:** تذكير موظفي الموارد البشرية بالتحقق من المستلم قبل إرسال الملفات الحساسة يدعم الإجراء الوقائي، لكنه لا يغني عن قاعدة منع فقدان البيانات أو التدريب الموجه.



SLIDE 43 · AWARENESS

التوعية



الأجهزة والأدوات

- رسائل منصة داخلية
- مواد مرئية
- إقرار سياسة
- استبيان

البروتوكولات والمعايير

- Security Awareness
- ECC-2:2024
- سياسات الجهة

الوظائف الرئيسية

- تعزيز السلوك اليومي المطلوب
- تحديد الرسالة
- ملاءمتها للفئة
- اختيار القناة
- قياس المشاركة

تذكير موظفي الموارد البشرية بالتحقق من المستلم قبل إرسال الملفات الحساسة يدعم الإجراء الوقائي، لكنه لا يغني عن قاعدة منع فقدان البيانات أو التدريب الموجه.

التوعية اتصال مستمر يركز على تذكير الفئات بالسلوك المطلوب والمخاطر والسياسات. وظيفتها دعم الالتزام اليومي وتقليل السلوكيات غير المقصودة المخالفة.



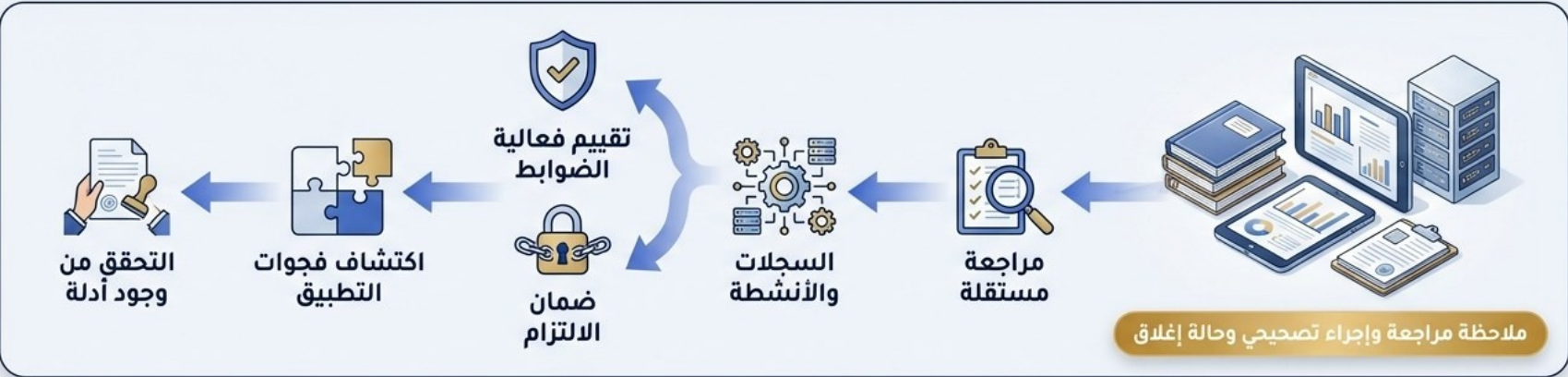
- ◀ المراجعة الداخلية مراجعة مستقلة للسجلات والأنشطة لتقييم فعالية الضوابط وضمان الالتزام.
- ◀ وظيفتها اكتشاف فجوات التطبيق والتحقق من وجود أدلة على التنفيذ.
- ◀ **الوظيفة:** التحقق من فعالية التنفيذ.
- ◀ **المسؤوليات:** تحديد النطاق، فحص الأدلة، توثيق الملاحظات، الإبلاغ، متابعة الإجراءات التصحيحية.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022، ECC-2:2024، السياسات والإجراءات الداخلية.
- ◀ **الأجهزة:** خطة مراجعة، قائمة تحقق، سجل أدلة، تقرير ملاحظات.
- ◀ **وحدة البيانات:** ملاحظة مراجعة وإجراء تصحيحي وحالة إغلاق.
- ◀ **مثال:** تتطلب خطة CAPA-2026-05-011 مراجعة عينة من رسائل البريد الخارجي ذات المرفقات السرية للتحقق من تطبيق ضوابط الاعتماد والمنع.



المراجعة الداخلية (Internal Audit) (الشكل)

SLIDE 44 · INTERNAL AUDIT

المراجعة الداخلية



الأجهزة والأدوات

- خطة مراجعة
- قائمة تحقق
- سجل أدلة
- تقرير ملاحظات

البروتوكولات والمعايير

- ECC-2:2024
- ISO/IEC 27001:2022
- السياسات والإجراءات الداخلية

الوظائف الرئيسية

- التحقق من فعالية التنفيذ
- تحديد النطاق
- فحص الأدلة
- توثيق الملاحظات
- الإبلاغ

تتطلب خطة CAPA-2026-05-011 مراجعة عينة من رسائل البريد الخارجي ذات المرفقات السرية للتحقق من تطبيق ضوابط الاعتماد والمنع.

المراجعة الداخلية مراجعة مستقلة للسجلات والأنشطة لتقييم فعالية الضوابط وضمان الالتزام. وظيفتها اكتشاف فجوات التطبيق والتحقق من وجود أدلة على التنفيذ.



- ◀ تختلف أداة الحد من المخاطر بحسب سبب الواقعة.
- ◀ التدريب يبني مهارة مرتبطة بدور محدد.
- ◀ التوعية تذكر بسلوك مطلوب بصورة متكررة.
- ◀ المراجعة الداخلية تتحقق من الأدلة وفعالية التطبيق.
- ◀ وقد يحتاج الخطر إلى ضابط تقني أو تعديل إجراء إضافة إلى هذه الأدوات.
- ◀ لا تعالج التوعية العامة وحدها فجوة تتطلب ضابط وصول أو قاعدة منع.

الأداة	الغرض	مثال تطبيقي	دليل الفاعلية
التدريب	بناء مهارة	التحقق من المستلم	سجل إتمام
التوعية	تذكير سلوكي	سياسة التصوير	سجل مشاركة
المراجعة الداخلية	فحص التطبيق	مراجعة البريد الخارجي	تقرير ملاحظات
ضابط تقني	منع أو تقليل التعرض	قاعدة منع فقدان البيانات	سجل تطبيق القاعدة



- ◀ التقرير الرسمي وثيقة منظمة تسجل الواقعة وتحليلها الأولي والإجراء والمسؤول والمتابعة.
- ◀ وظيفته توفير قابلية التتبع والمساءلة ودعم المراجعة واتخاذ القرار.
- ◀ **الوظيفة:** توثيق الواقعة وقرار المتابعة.
- ◀ **المسؤوليات:** تسجيل الوقائع، حماية السرية، تحديد التصعيد، تحديد الإجراء، حفظ النسخة المعتمدة.
- ◀ **البروتوكولات والمعايير:** إدارة المخاطر، متطلبات سرية البيانات، ضوابط ECC.
- ◀ **الأجهزة:** نموذج تقرير، نظام تذاكر، مستودع وثائق، سجل مخاطر.
- ◀ **وحدة البيانات:** تقرير واقعة أو خرق سياسة قابل للمراجعة.
- ◀ **مثال:** التقرير IR-2026-05-017 يوثق وقت الاكتشاف 10:35، والأصل المتأثر، والاحتواء، والأدلة، ومستوى الخطر، ومالك المتابعة.



التقرير الرسمي (Formal Report) (الشكل)

SLIDE 46 · FORMAL REPORT

التقرير الرسمي



الأجهزة والأدوات

- نموذج تقرير
- نظام تذاكر
- مستودع وثائق
- سجل مخاطر

البروتوكولات والمعايير

- إدارة المخاطر
- متطلبات سرية البيانات
- ضوابط ECC

الوظائف الرئيسية

- توثيق الواقعة وقرار المتابعة
- تسجيل الوقائع
- حماية السرية
- تحديد التصعيد
- تحديد الإجراء

التقرير IR-2026-05-017 يوثق وقت الاكتشاف 10:35، والأصل المتأثر، والاحتواء، والأدلة، ومستوى الخطر، ومالك المتابعة.

التقرير الرسمي وثيقة منظمة تسجل الواقعة وتحليلها الأولي والإجراء والمسؤول والمتابعة. وظيفته توفير قابلية التتبع والمساءلة ودعم المراجعة واتخاذ القرار.



حفظ الأدلة (Evidence Preservation)

- ◀ حفظ الأدلة هو المحافظة المنظمة على السجلات والوقائع والقرارات ذات الصلة بالحادث أو المخالفة.
- ◀ وظيفته دعم التتبع والمراجعة والتصعيد واتخاذ القرار بصورة قابلة للتحقق.
- ◀ **الوظيفة:** حفظ وقائع قابلة للمراجعة.
- ◀ **المسؤوليات:** تحديد السجل، حفظه وفق الصلاحية، حماية سرية، توثيق الوصول، عدم تعديله بلا مسار معتمد.
- ◀ **البروتوكولات والمعايير:** إدارة المخاطر، متطلبات السرية، مراجعة السجلات.
- ◀ **الأجهزة:** مستودع وثائق آمن، سجل حوادث، سجل وصول، نظام إدارة سجلات.
- ◀ **وحدة البيانات:** حزمة أدلة إدارية تضم سجلاً وتقريراً وقراراً وتاريخ متابعة.
- ◀ **مثال:** تحفظ الواقعة IR-2026-05-017 نسخة الرسالة وسجل وقت الإرسال وتأكيد الحذف ونسخة مقيدة الوصول من الملف المتأثر.



(الشكل) (Evidence Preservation) حفظ الأدلة

SLIDE 47 · EVIDENCE PRESERVATION

حفظ الأدلة



الأجهزة والأدوات

- مستودع وثائق آمن
- سجل حوادث
- سجل وصول
- نظام إدارة سجلات

البروتوكولات والمعايير

- إدارة المخاطر
- متطلبات السرية
- مراجعة السجلات

الوظائف الرئيسية

- حفظ وقائع قابلة للمراجعة
- تحديد السجل
- حفظه وفق الصلاحية
- حماية سرية
- توثيق الوصول

تحفظ الواقعة IR-2026-05-017 نسخة الرسالة وسجل وقت الإرسال وتأكيده الحذف ونسخة مقيدة الوصول من الملف المتأثر.

حفظ الأدلة هو المحافظة المنظمة على السجلات والوقائع والقرارات ذات الصلة بالحدث أو المخالفة.



مسار الاستجابة لحوادث خرق السياسات



- تبدأ الاستجابة باكتشاف الواقعة واحتوائها بحسب الصلاحية، مثل طلب حذف محتوى أو تعطيل رابط مشاركة.
- يوثق الفريق الوقائع ويحفظ الأدلة في وصول مقيد، ثم يقيم الأثر القانوني والأخلاقي والتشغيلي من دون إصدار حكم قانوني نهائي.
- بعد ذلك يعين الإجراء التصحيحي والوقائي ومالك المتابعة.
- ينتهي المسار بتقرير رسمي والتحقق من الفاعلية وإعادة تقدير الخطر المتبقي قبل الإغلاق.



وثقت العلاقة بين الواقعة وسجل الخطر وخطة الإجراء التصحيحي والوقائي.

ميزت التدريب الذي يبني مهارة مرتبطة بالدور، والتوعية التي تذكر بالسلوك، والمراجعة الداخلية التي تفحص الأدلة وفاعلية التنفيذ. أكمل نقطة التحقق في المنصة قبل الانتقال إلى النشاط التحليلي ومرحلة المشروع التراكمي.

ورقة العمل: ورقة عمل تحليل خرق السياسات ومعالجة المخاطر

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

ورقة عمل تحليل خرق السياسات ومعالجة المخاطر

#	الواقعة	التهديد أو الخطر المحدد	الضابط أو الإجراء المناسب ومبرره
1	يتشارك ثلاثة موظفين في خدمة المستخدمين كلمة مرور حساب مشرف لتسريع معالجة الطلبات.	فقدان المساءلة وإمكان إساءة استخدام صلاحيات مرتفعة، مع صعوبة نسبة العمليات إلى مستخدم محدد.	إيقاف الحساب المشترك فوراً وإنشاء حسابات فردية قائمة على الدور. يعد إيقاف إجراءً تصحيحياً، وتعد مراجعة سجلات الولوج والتدريب على مسؤولية الحسابات الشخصية إجراءات وقائية.
2	انتقل موظف من إدارة المشتريات إلى إدارة التسويق الرقمي وظلت صلاحياته السابقة لعروض الموردين فعالة.	وصول زائد إلى وثائق تعاقدية حساسة واحتمال تضارب المصالح أو إفشاء معلومات تجارية.	تخفيف الخطر بسحب الصلاحيات غير اللازمة ومراجعة فورية لحسابات المنقولين. يربط نظام الموارد البشرية بدورة حياة الهوية، وتنفذ مراجعة شهرية للصلاحيات بإشراف تقنية المعلومات.
3	ظهر في مقطع احتفالي منشور على منصة تواصل اجتماعي شاشة تعرض طلبات مستفيدين وأرقام هواتفهم.	كشف بيانات شخصية خارج غرض المعالجة المصرح به ومخالفة سياسة التصوير والنشر.	طلب حذف المحتوى وتوثيق الواقعة أولاً، ثم اعتماد مراجعة للمحتوى الإعلامي قبل النشر وتنفيذ توعية بسياسة التصوير داخل بيئة العمل.
4	احتفظ فريق عمل بملف بيانات مستفيدين على مساحة مشاركة عامة دون تحديد مالك للملف أو صلاحيات وصول واضحة.	وصول غير مصرح به إلى بيانات شخصية وغياب المساءلة عن الأصل المعلوماتي.	تخفيف الخطر بتعيين مالك أصل ونقل الملف إلى مساحة مقيدة الوصول وفق مبدأ الحد الأدنى من الصلاحيات، مع مراجعة دورية للمشاركات وسجل وصول.

يكشف المحرك الإجابات النموذجية تدريجياً بعد أن يكمل الطالب تحليله لكل واقعة.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- ◀ حل كل واقعة قبل الاطلاع على النموذج.
- ◀ حدد الأصل أو الحساب المتأثر، ثم اكتب التهديد المحدد.
- ◀ بعد ذلك اختر الضابط أو الإجراء المناسب وبيّن هل هو تصحيحي أم وقائي.
- ◀ في الواقعة الثالثة، يجب أن تفرق بين حذف المحتوى المنشور بوصفه احتواء أولياً، ومراجعة المحتوى الإعلامي بوصفها معالجة وقائية.



- ◀ يتشارك ثلاثة موظفين في خدمة المستخدمين كلمة مرور حساب مشرف لتسريع معالجة الطلبات.
- ◀ حل الخطر من حيث المساءلة وإمكان إساءة استخدام الصلاحيات المرتفعة.
- ◀ ثم اختر استراتيجية المعالجة من البدائل الأربع.
- ◀ اكتب إجراءً تصحيحياً فورياً وإجراءين وقائيين، وحدد دليلاً يمكن استخدامه للتحقق من اكتمال المعالجة.
- ◀ الزمن المتوقع عشر دقائق.



- ◀ تتمثل المشكلة في فقدان المساءلة وصعوبة نسبة العمليات إلى مستخدم محدد، مع إمكان إساءة استخدام صلاحيات مرتفعة.
- ◀ الاستراتيجية المناسبة هي تجنب المخاطر، لأن الحساب المشترك يوقف ولا يستمر مع تعديل بسيط.
- ◀ الإجراء التصحيحي هو إلغاء الحساب المشترك.
- ◀ وتشمل الإجراءات الوقائية إنشاء حسابات فردية قائمة على الدور، ومراجعة سجلات الولوج، وتدريب الموظفين على مسؤولية الحسابات الشخصية.



متابعة المعالجة (Treatment Monitoring)

- ◀ متابعة المعالجة هي التحقق المستمر من تنفيذ معالجة الخطر وفعاليتها وتغير مستوى الخطر المتبقي.
- ◀ وظيفتها منع تحول خطة المعالجة إلى وثيقة غير منفذة أو غير محدثة.
- ◀ **الوظيفة:** التحقق من التنفيذ والفاعلية.
- ◀ **المسؤوليات:** مراجعة الحالة، فحص الدليل، إعادة التقييم، التصعيد عند التأخر، إغلاق الإجراء بعد التحقق.
- ◀ **البروتوكولات والمعايير:** مرحلة المحافظة على التقييم، التحسين المستمر، مراجعة الضوابط.
- ◀ **الأجهزة:** سجل مخاطر، خطة إجراء تصحيحي، لوحة متابعة، تقرير مراجعة.
- ◀ **وحدة البيانات:** حالة محدثة مثل مفتوح أو قيد التنفيذ أو متأخر أو مكتمل أو مغلق بعد التحقق.
- ◀ **مثال:** تحدد CAPA-2026-05-011 تاريخ 2026-06-18 للتحقق من فاعلية قاعدة المنع وسجل إتمام التدريب قبل إغلاق الخطة.



متابعة المعالجة (Treatment Monitoring) (الشكل)

SLIDE 51 • TREATMENT MONITORING

متابعة المعالجة



الأجهزة والأدوات

- سجل مخاطر
- خطة إجراء صحي
- لوحة متابعة
- تقرير مراجعة

البروتوكولات والمعايير

- مرحلة المحافظة على التقييم
- التحسين المستمر
- مراجعة الضوابط

الوظائف الرئيسية

- التحقق من التنفيذ والفاعلية
- مراجعة الحالة
- فحص الدليل
- إعادة التقييم
- التصعيد عند التأخر

تحدد CAPA-2026-05-011 تاريخ 2026-06-18 للتحقق من فاعلية قاعدة المنع وسجل إتمام التدريب قبل إغلاق الخطة.

متابعة المعالجة هي التحقق المستمر من تنفيذ معالجة الخطر وفعاليتها وتغير مستوى الخطر المتبقي. وظيفتها منع تحول خطة المعالجة إلى وثيقة غير منفذة أو غير محدثة.

مثال محلول، تأخر سحب صلاحيات موظف منقول



المعطيات: الخطر R-2026-06 يتعلق باستمرار صلاحيات موظف منقول إلى عروض أسعار الموردين والوثائق التعاقدية لمدة شهرين.

الاحتمالية مرتفعة والأثر مرتفع، ومالك المعالجة مدير تقنية المعلومات بالتنسيق مع الموارد البشرية.

الخطوات:

1. يحدد الأصل والوثائق المتأثرة.
 2. يصنف الخطر قانونياً وأخلاقياً وتشغيلياً.
 3. يقرأ الاحتمالية والأثر ويحدد المستوى الحرج.
 4. يختار تخفيف المخاطر بسحب الصلاحيات ومراجعة الحسابات.
 5. يربط المتابعة بتقرير مراجعة الصلاحيات وسجل إقفال الوصول.
- الناتج: خطة معالجة ذات أولوية مرتفعة، تتضمن مالكاً ودليل متابعة وإجراءً وقائياً يربط الموارد البشرية بدورة حياة الهوية.



- عنوان المرحلة: سجل مخاطر قانونية وأخلاقية وإجراءات تصحيحية.
- ينفذ الفريق هذه المرحلة خلال 40 دقيقة.
- يضيف إلى حزمة مشروعه سجلاً يضم مخاطر مرتبطة بمؤسسته المختارة، وأصولاً متأثرة، ومستويات نوعية للاحتتمالية والأثر، واستراتيجيات معالجة، وملاك متابعة، وأدلة مقترحة.
- يرفق الفريق إجراءً تصحيحياً واحداً على الأقل مرتبطاً بخطر محدد.
- معياري الاكتمال: يتضمن السجل صفوفاً قابلة للتتبع، ولا يستخدم بيانات شخصية حقيقية أو أسماء منشآت أو أشخاص.
- التغذية الراجعة: يراجع الفريق السجل مقابل الروبرك، ثم يوثق الفجوات التي سيعالجها قبل تسليم الحزمة النهائية.



ملخص الوحدة السادسة ونقطة التحقق



اخترت أداة الحد من المخاطر بحسب سبب الواقعة، وربطت المتابعة بدليل فاعلية وحالة محدثة في السجل.

طبقت ذلك على مشاركة الحساب الإداري، ثم أضفت إلى مشروع الفريق سجلاً تمثيلاً للمخاطر وإجراءً تصحيحياً قابلاً للتتبع. أكمل نقطة التحقق في المنصة، وتحقق من حفظ المشروع بلا بيانات شخصية حقيقية.



✓ **الهدف الثاني:** حلت خرق السياسة بتحديد الأصل والسياسات والأثر والمسؤوليات والأدلة.

✓ **الهدف الأول:** ميزت بين المخاطر القانونية والأخلاقية والتشغيلية وربطت كل فئة بأثرها المحتمل.

✓ **الهدف الرابع:** قارنت بين التدريب والتوعية والمراجعة الداخلية والضوابط التقنية.

✓ **الهدف الثالث:** طبقت الاحتمالية والأثر ومصفوفة المخاطر لترتيب الأولويات نوعياً.

✓ **الهدف الخامس:** اقترحت تقريراً موثقاً وإجراءً تصحيحياً ووقائياً ومسار متابعة قابل للمراجعة.



◀ مصادر إلزامية:

1. Ross, R. (2012). Guide for Conducting Risk Assessments (NIST SP 800-30 Rev. 1). National Institute of Standards and Technology.
2. International Organization for Standardization & International Electrotechnical Commission. (2022). ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection, Information security management systems, Requirements (Edition 3).
3. الهيئة الوطنية للأمن السيبراني. (2024). الضوابط الأساسية للأمن السيبراني (ECC-2:2024).
4. المملكة العربية السعودية. نظام حماية البيانات الشخصية.
5. المملكة العربية السعودية. نظام مكافحة جرائم المعلوماتية، المرسوم الملكي رقم م/17.
6. Whitman, M. E., & Mattord, H. J. (2022). Principles of Information Security (7th ed.). Cengage Learning.
7. Stallings, W. (2018). Effective Cybersecurity: A Guide to Using Best Practices and Standards. Addison-Wesley Professional.



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شكراً لكم

معهد البحوث والخدمات الاستشارية – جامعة جازان